FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud scenarios, target controls and implementation programme

On its own answers, the organisation reports the controls in place for 102 of the 106 fraud scenarios that apply and a control reported as a gap in 4; 1 has answers to settle and 5 raise questions the answers do not settle.

CALCULATED TEST RESULT

87.8 of 100, test fixture

UNRESOLVED INCONSISTENCIES

1 to settle; 5 to clarify

PROVISIONAL MANAGEMENT INTERPRETATION

4 with a control reported as a gap

APPROVED READINESS CONCLUSION

None issued

PREPARED FOR

Fictional Retail Group (overstated confirmations)

Assessment reference · FX-P6b

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

HOW TO READ THIS REPORT

Contents

Management report	SECTIONS 1–9
1 · Where the organisation stands	
2 · What is driving the position	
3 · Reported fraud scenarios	
4 · How the scenarios could occur	
5 · The control environment management should build	
6 · Who must own the response	
7 · Decisions leadership must make	
8 · Proposed implementation stages	
9 · How management will know it is working	

Registers	APPENDICES A–J
A · Finding register	25 entries
B · Fraud risk register	5 entries
C · Control blueprint register	63 entries
D · Records management should maintain	61 entries
E · Action register	43 entries
F · Management scorecard	63 entries
G · Answer relationships	56 entries
H · Outstanding information	0 entries
I · Roles used in this report	13 entries
J · Information coverage	10 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report. The appendices hold every scenario, risk, control blueprint, record, action, measure, answer relationship and outstanding answer behind it, and the supporting workbook holds the same registers with the method references that trace each row to the question asked and the answer given.

BASIS OF THIS REPORT

TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. This report is produced by fixed rules from the organisation's answers to the MK Fraud Readiness review, read against the draft review method and the draft control-content library, neither of which MK has yet approved. The AI manuscript stage has not been run; the interpretation in each section is fixed-rule text. No evidence has been examined, no control has been tested for operating effectiveness, no one has been interviewed and no assurance opinion is given. Records named in this report are records management should maintain; independent review of evidence is a separate Advisory service.

SECTION 1 · WHERE THE ORGANISATION STANDS

What the assessment establishes

Four separate statements, made the same way for every organisation: what was calculated, what is inconsistent, how the answers read, and what has been concluded. Nothing here has been tested or verified.

CALCULATED TEST RESULT

87.8 of 100, test fixture

From a research simulation of the draft method, kept for traceability. It is not a score, a maturity band or a readiness level.

UNRESOLVED INCONSISTENCIES

1 to settle; 5 to clarify

1 scenario has answers that cannot both be right. A further 5 scenarios raise questions the answers do not settle. Until they are settled, the controls concerned are not treated as covering their scenarios.

PROVISIONAL MANAGEMENT INTERPRETATION

4 with a control reported as a gap

On its own answers, the organisation reports the controls that stop the scenario in place for 102 of the 106 fraud scenarios that apply, of which 6 are unresolved or open to question, and a control reported as a gap in 4. This reads self-reported answers; nothing has been tested.

APPROVED READINESS CONCLUSION

None issued

MK has not approved a readiness method, band or threshold, so no readiness conclusion is drawn from the answers or from the calculated test result.

AREA	SCENARIOS	IN PLACE	IN PLACE, RELATED PRACTICE WEAKER	GAP	TO SETTLE	TO CLARIFY	NOT ANALYSED	CALCULATED TEST RESULT*
Fraud governance and accountability	12	11	1	0	0	0	0	90.0
Fraud risk assessment	6	2	2	0	1	1	0	91.7
Ethics, integrity and anti-corruption	10	7	2	1	0	0	0	81.0
Third parties and supply chain	13	9	2	1	0	1	0	85.7
People, payroll and insider risk	11	7	2	1	0	1	0	89.1
Finance, banking and financial reporting	12	11	1	0	0	0	0	92.5
Customers, revenue and products	10	9	1	0	0	0	0	92.0
Assets, cash and inventory	10	7	1	1	0	1	0	82.0
Digital, cyber-enabled and identity fraud	14	13	1	0	0	0	0	87.1
Detection, speak-up and response	8	5	2	0	0	1	0	86.7

* TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. Shown for traceability only: not a score, a band or a ranking of the areas.

WHAT THIS MEANS

The organisation answered 108 of the 108 confirmations that apply, 45 of 45 in the core stage. Of the diagnostic questions put to it, 59 of 59 were answered; the rest of the method's diagnostic questions were not asked, and nothing is concluded about them (Appendix J). The tier of a scenario says how early the method asks about it, not how serious it is, and the calculated test result is not a readiness level.

SECTION 2 · WHAT IS DRIVING THE POSITION

The patterns behind the answers

Answers to settle and questions to clarify first, because a control relied on as reported may not operate that way; then requirements that span areas, and the count of gaps by area.

Answers to settle and questions to clarify

Where a control was reported fully in place and a related practice of the same scenario weaker, the two answers were compared using MK's reviewed relationships. A conflict is recorded only where both answers describe the same fact; incomplete documentation, such as a missing list or rating, is not treated as proof that a control cannot operate, and is raised as a question instead. Every pair, including those not yet reviewed, is in Appendix G.

SCENARIO	STATUS	WHAT THE ANSWERS SAY, AND THE QUESTION TO ANSWER	OWNER
AI-enabled schemes are not considered S14 · Fraud risk assessment	ANSWERS THAT CANNOT BOTH BE RIGHT	The answers about AI-enabled fraud cannot both be right as given: one says AI-enabled schemes are assessed for every relevant process, the other that, for high-risk processes, the assessment does not ask how AI could be used against them.	Fraud risk lead
Risks above tolerance are left without action S17 · Fraud risk assessment	QUESTION TO CLARIFY	A response is reported as decided for every risk above tolerance, while rating each risk for likelihood and harm is reported as not in place. Risks above tolerance can be identified without ratings, but the answers do not say how this is done. **Question:** Without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response?	Fraud risk lead
Invoices are paid for goods or services not received or not agreed S33 · Third parties and supply chain	QUESTION TO CLARIFY	Every invoice is reported as checked against an approved order and a confirmation of receipt before payment, while recording receipt of goods before payment is reported as partly in place. The check may rely on another confirmation where receipt is not recorded; the answers do not say which. Every invoice, including for services, is reported as checked against a confirmation of receipt before payment, while confirmation of delivery by the person who received the service is reported as not in place. Someone else may confirm delivery; the answers do not say who. **Question:** For deliveries where receipt is not recorded before the invoice is paid, what confirmation of receipt does the invoice check rely on, and who gives it? For service invoices, who confirms that the service was delivered before payment, and is that confirmation recorded?	Finance lead
An insider in a high-risk role works unchecked S52 · People, payroll and insider risk	QUESTION TO CLARIFY	Block leave is reported for everyone in a sensitive role, while identifying high-risk roles on a maintained list is reported as partly in place. The requirement can reach every sensitive role without a list, but the answers do not show how management knows that it does. **Question:** Without a maintained list of high-risk roles, how does management confirm that the block leave requirement reaches every sensitive role?	HR and payroll lead
Stock is stolen and hidden in the counts S76 · Assets, cash and inventory	QUESTION TO CLARIFY	Counts are reported as independent and blind to recorded quantities, while stock is reported as not formally recorded. A count reveals a loss only when it is compared with an expected quantity; the answers do not say what the counts are compared with. **Question:** What is each stock count compared with to identify losses, given that stock is not formally recorded?	Finance lead
An investigation is not independent or fair S102 · Detection, speak-up and response	QUESTION TO CLARIFY	Investigations are reported as always independent of the area concerned, and suspected fraud as investigated by line management or HR. Both can be right if HR or a manager from another area investigates; the answers do not say whether line managers ever investigate their own area. **Question:** When suspected fraud is investigated, does a line manager ever investigate a matter in the area they manage, and if so, how is independence achieved?	Investigations lead

Requirements that span several areas

The method groups some controls into requirements that cross areas. Where two or more of them are reported as gaps in different areas, the weakness is connected: fixing one area leaves the route open through another.

REQUIREMENT	CONTROLS REPORTED AS GAPS	IN PLACE OF THOSE ASKED
Independent assurance examines high-risk processes	Independent review of procurement (procurement: partly in place); Independent review of payroll (people: partly in place)	0 of 2

Scenarios with a control reported as a gap, by area

AREA	SCENARIOS WITH A GAP	SCENARIOS IN THE AREA
Ethics, integrity and anti-corruption	1	10
Third parties and supply chain	1	13
People, payroll and insider risk	1	11
Assets, cash and inventory	1	10

Areas in the method's order. A count of scenarios is not a measure of their seriousness.

WHAT THIS MEANS

1 scenario has answers to settle and 5 scenarios raise questions the answers do not settle. These come first, because the controls concerned are reported in place and the answers do not yet establish that they cover their scenarios. 1 requirement spans several areas with gaps in more than one. 4 scenarios have a control reported as a gap, across 4 areas.

SECTION 3 · REPORTED FRAUD SCENARIOS

The scenarios this report acts on, by area

Every scenario with answers to settle, a question to clarify or a control reported as a gap, in the method's order. MK has not approved a method for rating fraud risks, so no likelihood, impact, materiality or priority is assigned, and neither the order nor the tier is a ranking. Each scenario's finding is in Appendix A and its risk statement in Appendix B.

AREA	ACTED ON	SCENARIOS
Fraud risk assessment	2	AI-enabled schemes are not considered S14 TO SETTLE; Risks above tolerance are left without action S17 TO CLARIFY
Ethics, integrity and anti-corruption	1	Donations or sponsorships channel bribes S26
Third parties and supply chain	2	Invoices are paid for goods or services not received or not agreed S33 TO CLARIFY; Procurement anomalies are never noticed S40
People, payroll and insider risk	2	Hours and overtime are inflated S49; An insider in a high-risk role works unchecked S52 TO CLARIFY
Assets, cash and inventory	2	Stock is stolen and hidden in the counts S76 TO CLARIFY; Losses are never tracked S84
Detection, speak-up and response	1	An investigation is not independent or fair S102 TO CLARIFY

A further 15 scenarios have the control that stops it reported in place with a related practice weaker. They are in Appendix A, and the related practices in Appendix C.

WHAT THIS MEANS

10 scenarios are acted on across 6 areas. The grouping shows where the work sits; Section 7 asks management to decide the order, using explicit factors.

SECTION 4 · HOW THE SCENARIOS COULD OCCUR

Illustrative exposure mechanisms

Included: every scenario with answers to settle or a question to clarify (up to three), then the first scenario with a control reported as a gap in each area, in the method's order, up to six in all. They are plausible pathways for an organisation with the controls it reported, not allegations that any event has occurred, and their inclusion is not a ranking.

AI-enabled schemes are not considered

S14 · FRAUD RISK ASSESSMENT

HOW IT STARTS	Deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk.
WHY IT MATTERS	These schemes defeat controls that rely on recognising a person or a document.
WHAT THE ANSWERS SHOW	The answers about AI-enabled fraud cannot both be right as given: one says AI-enabled schemes are assessed for every relevant process, the other that, for high-risk processes, the assessment does not ask how AI could be used against them.
WHAT WOULD INTERRUPT IT	Establishing which answer is right; until then, the scenario is not treated as covered.
WARNING SIGNS	AI-enabled fraud not anticipated
LINKS	F03, FR01, C12, C10, C11, C13, C09

Risks above tolerance are left without action

S17 · FRAUD RISK ASSESSMENT

HOW IT STARTS	Assessment results do not change controls, audit work or training.
WHY IT MATTERS	The method links it to effort and audit work not directed at the highest fraud risks.
WHAT THE ANSWERS SHOW	A response is reported as decided for every risk above tolerance, while rating each risk for likelihood and harm is reported as not in place. Risks above tolerance can be identified without ratings, but the answers do not say how this is done.
WHAT WOULD INTERRUPT IT	Without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response? The answer decides whether anything needs to change.
WARNING SIGNS	Effort and audit work not directed at the highest fraud risks
LINKS	F04, C14

Invoices are paid for goods or services not received or not agreed

S33 · PROCUREMENT

HOW IT STARTS	Overbilling, fictitious deliveries or inflated rates are paid.
WHY IT MATTERS	Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.
WHAT THE ANSWERS SHOW	Every invoice is reported as checked against an approved order and a confirmation of receipt before payment, while recording receipt of goods before payment is reported as partly in place. The check may rely on another confirmation where receipt is not recorded; the answers do not say which. Every invoice, including for services, is reported as checked against a confirmation of receipt before payment, while confirmation of delivery by the person who received the service is reported as not in place. Someone else may confirm delivery; the answers do not say who.
WHAT WOULD INTERRUPT IT	For deliveries where receipt is not recorded before the invoice is paid, what confirmation of receipt does the invoice check rely on, and who gives it? The answer decides whether anything needs to change.
WARNING SIGNS	Duplicate or false invoices; Goods or services paid for but not received
LINKS	F10, C29, C30, C31

Donations or sponsorships channel bribes

S26 · ETHICS

HOW IT STARTS	A payment to a cause linked to a decision-maker buys influence.
WHY IT MATTERS	The method links it to donations and sponsorships used as disguised bribes and undeclared conflicts of interest steering decisions.
WHAT THE ANSWERS SHOW	Recipients checked for links: reported in place only in some areas, cases or periods.
WHAT WOULD INTERRUPT IT	Before any donation or sponsorship is committed, the recipient is checked for links to public officials, customers' decision-makers and employees, and any link found is disclosed and approved.
WARNING SIGNS	Donations and sponsorships used as disguised bribes; Undeclared conflicts of interest steering decisions
LINKS	F08, FR02, C23

Procurement anomalies are never noticed

S40 · PROCUREMENT

HOW IT STARTS	Patterns such as splitting or duplicates go unseen.
WHY IT MATTERS	The method does not describe the consequence of this scenario.
WHAT THE ANSWERS SHOW	Senior review of supplier payments: reported in place only in some areas, cases or periods. Behind it, split orders monitored is set out, not yet operating, data reviewed for unusual patterns is not in place and independent review of procurement is partly in place.
WHAT WOULD INTERRUPT IT	Each month a senior manager who does not process payments reviews the list of supplier payments for unfamiliar suppliers, unusual amounts and changed bank details, and follows up each query.
WARNING SIGNS	The method names none for this scenario.
LINKS	F11, FR03, C35, C34, C32, C33

Hours and overtime are inflated

S49 · PEOPLE

HOW IT STARTS	Unworked hours or overtime are approved and paid.
WHY IT MATTERS	The method links it to timesheet, overtime and leave abuse.
WHAT THE ANSWERS SHOW	Hours approved by supervisor: reported in place only in some areas, cases or periods.
WHAT WOULD INTERRUPT IT	Hours and overtime are approved by the employee's supervisor, against the roster or attendance record, before they are paid.
WARNING SIGNS	Timesheet, overtime and leave abuse
LINKS	F15, FR04, C43

4 further scenarios are described in Appendices A and B.

SECTION 5 · THE CONTROL ENVIRONMENT MANAGEMENT SHOULD BUILD

Target controls, by accountable role

One programme for each accountable role, in alphabetical order. Each control's blueprint, with its target practice, activities, records and success measure, is in Appendix C; here it is named with its reference.

Chief executive

2 CONTROLS

STRENGTHEN	Owner has authority across the organisation (C01); Dedicated fraud capability (C02).

Chief financial officer

2 CONTROLS

STRENGTHEN	Annual fraud action plan (C03); Qualified fraud leads (C04).

Commercial and customer lead

1 CONTROL

STRENGTHEN	Refunds to the original source (C49).

Ethics lead

4 CONTROLS

SCENARIOS	donations or sponsorships channel bribes.
PUT IN PLACE	Recipients checked for links (C23).
STRENGTHEN	Programme independently reviewed (C21); Trends reported upward (C22); Retaliation risk assessed (C62).

Finance lead

4 CONTROLS

SCENARIOS	procurement anomalies are never noticed and losses are never tracked.
PUT IN PLACE	Senior review of supplier payments (C35); Losses tracked and reported (C59).
STRENGTHEN	Capture and authorise separated (C48); Differences explained before adjusting (C57).

Fraud risk lead

12 CONTROLS

SCENARIOS	AI-enabled schemes are not considered.
SETTLE THE ANSWERS	AI-enabled fraud covered (C09); AI methods tested per process (C11).
STRENGTHEN	Risks described as schemes (C05); Processes walked through (C06); Management owns the results (C07); Process owners take part (C08); Own AI tools in scope (C10); Controls tested against AI fakes (C12); Simulated AI attack (C13); Likelihood and impact rated (C14); Assessment documented (C15); Owners know their risks (C16).

HR and payroll lead

12 CONTROLS

SCENARIOS	hours and overtime are inflated.
PUT IN PLACE	Hours approved by supervisor (C43).
STRENGTHEN	Leaders trained on their duties (C17); Training on joining (C19); Written code of conduct (C20); Bank change report reviewed (C39); New employee checked by another person (C40); Payroll data analysed (C41); Independent review of payroll (C42); High-risk roles identified (C44); No conflicting duties when covering (C45); Concerns raised fairly (C46); Support for financial pressure (C47).

Internal audit

2 CONTROLS

STRENGTHEN	Data reviewed for unusual patterns (C32); Independent review of procurement (C33).

Investigations lead

2 CONTROLS

STRENGTHEN	Speak-up channel (C61); Who investigates (C63).

IT lead

1 CONTROL

STRENGTHEN	Mailbox rules and odd logins alerted (C60).

Legal and compliance lead

1 CONTROL

STRENGTHEN	High-risk activities identified (C18).

Operations lead

10 CONTROLS

STRENGTHEN	Receipt recorded before payment (C30); Services confirmed (C31); Dual control at hand-overs (C50); Deposits reconciled independently (C51); Takings checked against an independent record (C52); Store access limited (C53); Issues against approved requests (C54); Custody separated from records (C55); High-value items secured (C56); How stock is recorded (C58).

Procurement lead

10 CONTROLS

STRENGTHEN	New supplier approved by another person (C24); Directors identified (C25); Directors compared with staff (C26); Suppliers re-checked (C27); Dormant suppliers deactivated (C28); Approved order before commitment (C29); Split orders monitored (C34); Contract register (C36); Large variations escalated (C37); Written supplier contracts (C38).

WHAT THIS MEANS

4 controls are to be put in place, 2 need their answers settled and 57 are related practices to strengthen. No reviewed relationship establishes that one of these controls consumes another's output, so no control is sequenced before another for that reason. Each blueprint comes from MK's draft control-content library (control-content-library-0.1), which MK has not yet approved.

SECTION 6 · WHO MUST OWN THE RESPONSE

Accountability by role

Roles, not individuals: the assessment does not identify people. The method suggests owners in many forms; this report uses one label per function, and Appendix I lists the method's wording behind each. Oversight: the board, from the organisation's own answer.

ROLE	CONTROLS	SCENARIOS	ACTIONS	ANSWERS TO SETTLE OR QUESTIONS TO ANSWER
Chief executive	2	6	10	Names the accountable executives, decides the order of work and reports status to the board.
Chief financial officer	2	1	2	None
Commercial and customer lead	1	1	2	None
Ethics lead	4	3	3	None
Finance lead	4	4	5	Invoices are paid for goods or services not received or not agreed; Stock is stolen and hidden in the counts.
Fraud risk lead	12	4	4	AI-enabled schemes are not considered; Risks above tolerance are left without action.
HR and payroll lead	12	6	4	An insider in a high-risk role works unchecked.
Internal audit	2	1	2	None
Investigations lead	2	2	3	An investigation is not independent or fair.
IT lead	1	1	2	None
Legal and compliance lead	1	1	2	None
Operations lead	10	3	2	None
Procurement lead	10	4	2	None

SECTION 7 · DECISIONS LEADERSHIP MUST MAKE

The decision agenda

A recommended direction follows the method and the answers; the decision remains management's. No deadline is set: "when" states what each decision must come before.

REF	DECISION	WHY	RECOMMENDED DIRECTION	WHEN	IF DELAYED
D01	**Have the answers that cannot both be right settled, and the questions the answers leave open answered, before the controls concerned are relied on.**	1 scenario has answers that cannot both be right and 5 scenarios raise questions that the answers do not settle.	Ask each process owner to establish how the process runs, record the answer, and correct the assessment where it was wrong.	Before the controls concerned are relied on or reported as in place.	The organisation may rely on a control whose operation the answers do not establish.
D02	**Name one accountable executive for each area with open or unresolved scenarios: fraud risk assessment (1), ethics (1), procurement (1), people (1) and assets (1).**	Each scenario needs one person with authority over the process, the system and the people involved.	The method suggests: fraud risk lead for fraud risk assessment, ethics lead for ethics, procurement lead for procurement, HR and payroll lead for people and operations lead for assets.	Before design work starts.	Open scenarios have no owner, and the controls that stop them stay unassigned.
D03	**Decide the order in which the open scenarios are addressed, using explicit factors.**	MK has not approved a method for rating fraud risks, so this report does not rank them, and neither its order nor the method's tiers is a ranking.	Settle conflicting answers and open questions first. Then weigh, for each scenario, how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much activity passes through the process, whether another control would detect a loss, and how many other scenarios the same control serves. The finding register gives the facts the assessment holds for the first and last of these; management supplies the rest.	Before design work starts.	Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.
D04	**Have the board receive the status of the open and unresolved scenarios at each of its meetings until each is closed, deferred with a reason or accepted.**	Regular reporting keeps the scenarios visible to the people who can remove blockers.	A one-page status per scenario: owner, controls in place, controls outstanding, next step.	From the first meeting after this report.	Progress is not visible until the next assessment.

SECTION 8 · PROPOSED IMPLEMENTATION STAGES

A twelve-month programme, in proposed stages

Each stage has a proposed planning window for when it could start. The windows are proposals for management's own plan: not deadlines, not contractual dates and not estimates of how long any control takes to design, put in place or show to be operating. Every action is in Appendix E.

STAGE	STAGE	PROPOSED WINDOW	PURPOSE	ACTIONS	INCLUDES
1	**Establish the facts**	Proposed start: month 1	Settle answers that cannot both be right, answer the questions the answers leave open, and obtain outstanding answers, so that nothing is built on an answer that may be wrong.	6	Establish which answer is right for the scenario where AI-enabled schemes are not considered: AI-enabled fraud covered and AI methods tested per process. Answer the question the answers leave open for the scenario where risks above tolerance are left without action: without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response? 4 more in Appendix E.
2	**Decide and assign**	Proposed start: months 1 to 3	Name who is accountable for each area, decide the order of work using explicit factors, and approve the target designs.	7	Name the executive accountable for fraud risk assessment, where 1 scenario is open or unresolved. Name the executive accountable for ethics, where 1 scenario is open or unresolved. 5 more in Appendix E.
3	**Put the selected controls in place**	Proposed start: once designs are approved	The controls reported as gaps for the scenarios management has selected.	3	Put in place the control the ethics lead owns: recipients checked for links (C23). Put in place the 2 controls the finance lead owns: senior review of supplier payments (C35) and losses tracked and reported (C59). 1 more in Appendix E.
4	**Strengthen further defences**	Proposed start: after the first controls are in place	Related practices reported weaker behind a control reported in place or a gap.	13	Strengthen the 2 controls the chief executive owns: owner has authority across the organisation (C01) and dedicated fraud capability (C02). Strengthen the 2 controls the chief financial officer owns: annual fraud action plan (C03) and qualified fraud leads (C04). 11 more in Appendix E.
5	**Operate, measure and report**	From the first control in operation, through month 12	Run each control through at least one full operating cycle, check it against its success measure and report status to the oversight body.	14	Check each of the 2 controls owned by the chief executive against its success measure once it has completed its first full operating cycle. Check each of the 2 controls owned by the chief financial officer against its success measure once it has completed its first full operating cycle. 12 more in Appendix E.

WHAT THIS MEANS

The first two stages need no new control: they establish the facts, name owners and decide the order of work. No control here consumes another's output as far as reviewed relationships establish, so no prerequisite stage is needed. A control counts as working only after it has met its success measure for at least one full operating cycle; for annual controls that may fall beyond the twelve months. Status is reported to the board throughout.

SECTION 9 · HOW MANAGEMENT WILL KNOW IT IS WORKING

Indicators and the management scorecard

Each control has one success measure, stated as the outcome its records should show for a period (Appendix F). They are the signals management should expect once a control operates, not a claim that they exist today.

INDICATOR	TODAY	EXPECTED
Scenarios with answers to settle	1	None; each corrected answer recorded
Questions the answers leave open	5	Each answered in writing and added to the record
Open scenarios with a named owner and a recorded decision	None recorded (4 open)	Every open scenario selected, deferred with a reason or accepted
Controls meeting their success measure for a full cycle	Not measured	Each control put in place (4), then each related practice strengthened
Status reported to the board	Not yet	At each meeting until each scenario is closed, deferred or accepted

The scorecard, by owner

OWNER	MEASURES	MOST COMMON OPERATING CYCLES
Chief executive	2	each year (2)
Chief financial officer	2	each year (2)
Commercial and customer lead	1	before each refund is paid (1)
Ethics lead	4	within the last three years (1); at least twice a year (1); before each commitment (1)
Finance lead	4	monthly (2); each quarter (1); after each count (1)
Fraud risk lead	12	at each assessment and update (7); at each assessment (2); after each assessment (2)
HR and payroll lead	12	each year (4); each pay run (2); monthly (1)
Internal audit	2	monthly (1); within the last two years (1)
Investigations lead	2	each year (2)
IT lead	1	daily (1)
Legal and compliance lead	1	at each assessment and update (1)
Operations lead	10	before each payment (2); daily (2); monthly (2)
Procurement lead	10	each quarter (3); before each new supplier becomes active (1); before each new supplier is first paid (1)

CONCLUSION

On its own answers, Fictional Retail Group (overstated confirmations) reports the controls in place for 102 of 106 fraud scenarios and a control reported as a gap in 4. The first task is to settle the answers for 1 scenario and answer the 5 open questions. MK has not approved a readiness method, so the report draws no readiness conclusion and does not rank fraud risks; it sets out what each scenario needs, who owns it, the records to keep and how management will know each control is working.

APPENDIX A

Finding register

Every scenario with answers to settle, a question to clarify, a control reported as a gap or a related practice weaker, in the method's order. "What the answers show" is self-reported and has not been verified. Decision factors are the facts the assessment holds for ordering the work; they are not a rating.

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F01 S01	**No one is answerable for fraud risk** Fraud governance and accountability CONTROL IN PLACE; RELATED PRACTICE WEAKER	Executive accountable for fraud: it is written into a named executive's role. Related practices reported weaker: owner has authority across the organisation (not in place), dedicated fraud capability (partly in place), annual fraud action plan (partly in place) and qualified fraud leads (partly in place). Answered by the respondent, Executive and governance and Finance.	Gaps persist because nobody owns fraud risk or has the authority to act. Without a named, accountable person, other controls decay unnoticed.	In place; related practice weaker C01, C02, C03, C04
F02 S13	**Fraud risks are never identified** Fraud risk assessment CONTROL IN PLACE; RELATED PRACTICE WEAKER	Fraud risks assessed: in a dedicated fraud risk assessment. Related practices reported weaker: management owns the results (not in place), process owners take part (not in place), risks described as schemes (partly in place) and processes walked through (not in place). Answered by the respondent and Risk and investigations.	Management does not know how fraud could happen in its own processes. Whether risks are understood decides whether controls are aimed at the right schemes.	In place; related practice weaker C07, C08, C05, C06
F03 S14	**AI-enabled schemes are not considered** Fraud risk assessment ANSWERS THAT CANNOT BOTH BE RIGHT	The answers about AI-enabled fraud cannot both be right as given: one says AI-enabled schemes are assessed for every relevant process, the other that, for high-risk processes, the assessment does not ask how AI could be used against them. Answered by Risk and investigations and the respondent.	Deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk. These schemes defeat controls that rely on recognising a person or a document.	Answers that cannot both be right FR01, C12, C10, C11, C13, C09
F04 S17	**Risks above tolerance are left without action** Fraud risk assessment QUESTION TO CLARIFY	A response is reported as decided for every risk above tolerance, while rating each risk for likelihood and harm is reported as not in place. Risks above tolerance can be identified without ratings, but the answers do not say how this is done. **Question:** Without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response? Answered by Risk and investigations and the respondent.	Assessment results do not change controls, audit work or training.	Question to clarify C14
F05 S18	**The assessment goes stale as the business changes** Fraud risk assessment CONTROL IN PLACE; RELATED PRACTICE WEAKER	Updated when the business changes: change projects include a fraud risk step by default, and the assessment owner confirms the update is complete. Related practices reported weaker: assessment documented (partly in place) and owners know their risks (not in place). Answered by the respondent and Risk and investigations.	New products, structures and threats are not assessed.	In place; related practice weaker C15, C16
F06 S19	**Bribes are paid or accepted, directly or through others** Ethics, integrity and anti-corruption CONTROL IN PLACE; RELATED PRACTICE WEAKER	Bribery prohibited: the rule covers every form of bribery, including through agents, applies to everyone acting for the organisation and is communicated. Related practices reported weaker: high-risk activities identified (partly in place) and leaders trained on their duties (set out, not yet operating). Answered by the respondent and HR and payroll.	Staff or intermediaries offer or accept gratification to win or retain business. PRECCA criminalises bribery in both sectors, including bribes paid through others.	In place; related practice weaker C18, C17

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F07 S25	**Staff do not know or understand what is expected** Ethics, integrity and anti-corruption CONTROL IN PLACE; RELATED PRACTICE WEAKER	Code accessible to staff: reported in place across everything it should cover. Related practices reported weaker: written code of conduct (not in place), training on joining (set out, not yet operating), programme independently reviewed (not in place) and trends reported upward (not in place). Answered by HR and payroll, the respondent and Legal, compliance and ethics.	Expectations are not communicated in a way people understand, and nobody checks.	In place; related practice weaker C20, C19, C21, C22
F08 S26	**Donations or sponsorships channel bribes** Ethics, integrity and anti-corruption CONTROL REPORTED AS A GAP	Recipients checked for links: reported in place only in some areas, cases or periods. Answered by the respondent.	A payment to a cause linked to a decision-maker buys influence.	Partly in place FR02, C23
F09 S29	**A fictitious supplier is created and paid** Third parties and supply chain CONTROL IN PLACE; RELATED PRACTICE WEAKER	New supplier process: every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Related practices reported weaker: new supplier approved by another person (not in place), directors identified (partly in place), directors compared with staff (not in place), suppliers re-checked (set out, not yet operating) and dormant suppliers deactivated (not in place). Answered by the respondent and Procurement.	An insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped.	In place; related practice weaker C24, C25, C26, C27, C28
F10 S33	**Invoices are paid for goods or services not received or not agreed** Third parties and supply chain QUESTION TO CLARIFY	Every invoice is reported as checked against an approved order and a confirmation of receipt before payment, while recording receipt of goods before payment is reported as partly in place. The check may rely on another confirmation where receipt is not recorded; the answers do not say which. Every invoice, including for services, is reported as checked against a confirmation of receipt before payment, while confirmation of delivery by the person who received the service is reported as not in place. Someone else may confirm delivery; the answers do not say who. **Question:** For deliveries where receipt is not recorded before the invoice is paid, what confirmation of receipt does the invoice check rely on, and who gives it? For service invoices, who confirms that the service was delivered before payment, and is that confirmation recorded? Answered by Procurement, Operations and sales and the respondent.	Overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.	Question to clarify C29, C30, C31
F11 S40	**Procurement anomalies are never noticed** Third parties and supply chain CONTROL REPORTED AS A GAP	Senior review of supplier payments: reported in place only in some areas, cases or periods. Related practices also reported weaker: split orders monitored (set out, not yet operating), data reviewed for unusual patterns (not in place) and independent review of procurement (partly in place). Answered by Procurement, the respondent and Risk and investigations.	Patterns such as splitting or duplicates go unseen.	Partly in place FR03, C35, C34, C32, C33
F12 S41	**Variations inflate the agreed value** Third parties and supply chain CONTROL IN PLACE; RELATED PRACTICE WEAKER	Variations approved first: reported in place across everything it should cover. Related practices reported weaker: written supplier contracts (partly in place), contract register (not in place) and large variations escalated (set out, not yet operating). Answered by Procurement and the respondent.	Extra scope or rates are approved after the work is done.	In place; related practice weaker C38, C36, C37
F13 S42	**Salaries are redirected through a fake bank change** People, payroll and insider risk CONTROL IN PLACE; RELATED PRACTICE WEAKER	Bank changes confirmed with employee: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. Related practices reported weaker: bank change report reviewed (partly in place). Answered by the respondent.	A request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast.	In place; related practice weaker C39

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F14 S43	**Ghost employees are paid** People, payroll and insider risk CONTROL IN PLACE; RELATED PRACTICE WEAKER	Payroll reviewed by another person: the review follows a standard checklist, exceptions are followed up and findings are tracked over time. Related practices reported weaker: new employee checked by another person (partly in place), payroll data analysed (set out, not yet operating) and independent review of payroll (partly in place). Answered by HR and payroll and the respondent.	Fictitious or departed people stay on the payroll. A payroll that nobody independent reviews before payment is where ghost employees hide.	In place; related practice weaker C40, C41, C42
F15 S49	**Hours and overtime are inflated** People, payroll and insider risk CONTROL REPORTED AS A GAP	Hours approved by supervisor: reported in place only in some areas, cases or periods. Answered by the respondent.	Unworked hours or overtime are approved and paid.	Partly in place FR04, C43
F16 S52	**An insider in a high-risk role works unchecked** People, payroll and insider risk QUESTION TO CLARIFY	Block leave is reported for everyone in a sensitive role, while identifying high-risk roles on a maintained list is reported as partly in place. The requirement can reach every sensitive role without a list, but the answers do not show how management knows that it does. **Question:** Without a maintained list of high-risk roles, how does management confirm that the block leave requirement reaches every sensitive role? Answered by HR and payroll and the respondent.	Someone who never hands over work conceals an ongoing fraud.	Question to clarify C44, C45, C46, C47
F17 S53	**An unauthorised payment leaves the bank** Finance, banking and financial reporting CONTROL IN PLACE; RELATED PRACTICE WEAKER	Two authorisers for every payment: the bank's platform enforces two authorisers for every payment. Related practices reported weaker: capture and authorise separated (not in place). Answered by the respondent.	One person can release money, on the platform or through a branch instruction. Two-person release enforced where money leaves is the last barrier before a payment goes.	In place; related practice weaker C48
F18 S65	**Refunds are stolen** Customers, revenue and products CONTROL IN PLACE; RELATED PRACTICE WEAKER	Refunds approved independently: the system enforces the approval, and approvals are reviewed for patterns. Related practices reported weaker: refunds to the original source (not in place). Answered by the respondent.	One person raises and approves refunds or credit notes to themselves or accomplices. Refunds processed and approved by one person are a classic way to steal.	In place; related practice weaker C49
F19 S75	**Cash takings are stolen** Assets, cash and inventory CONTROL IN PLACE; RELATED PRACTICE WEAKER	Daily reconciliation: takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. Related practices reported weaker: dual control at hand-overs (partly in place), takings checked against an independent record (partly in place) and deposits reconciled independently (partly in place). Answered by Operations and sales and the respondent.	Takings are under-recorded or removed before banking. Daily reconciliation of takings is the main control over cash theft.	In place; related practice weaker C50, C52, C51
F20 S76	**Stock is stolen and hidden in the counts** Assets, cash and inventory QUESTION TO CLARIFY	Counts are reported as independent and blind to recorded quantities, while stock is reported as not formally recorded. A count reveals a loss only when it is compared with an expected quantity; the answers do not say what the counts are compared with. **Question:** What is each stock count compared with to identify losses, given that stock is not formally recorded? Answered by Operations and sales, the respondent and Finance.	The people who hold stock also count it. Counts done by the people who hold the stock can hide its theft.	Question to clarify C58, C53, C54, C55, C56, C57
F21 S84	**Losses are never tracked** Assets, cash and inventory CONTROL REPORTED AS A GAP	Losses tracked and reported: reported in place only in some areas, cases or periods. Answered by the respondent.	Shrinkage and losses are written off without analysis.	Partly in place FR05, C59
F22 S85	**An email account is taken over** Digital, cyber-enabled and identity fraud CONTROL IN PLACE; RELATED PRACTICE WEAKER	Multi-factor on all email: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. Related practices reported weaker: mailbox rules and odd logins alerted (not in place). Answered by the respondent.	A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.	In place; related practice weaker C60

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F23 S99	**Concerns are never reported** Detection, speak-up and response CONTROL IN PLACE; RELATED PRACTICE WEAKER	People know whom to tell: all employees know at least two people they can tell, including one outside their reporting line, and that the Protected Disclosures Act protects them. Related practices reported weaker: speak-up channel (partly in place). Answered by the respondent.	People who suspect fraud have no safe route, or do not know whom to tell. Tips are the most common way fraud is detected, and safe routes decide whether people report.	In place; related practice weaker C61
F24 S100	**A reporter is exposed or retaliated against** Detection, speak-up and response CONTROL IN PLACE; RELATED PRACTICE WEAKER	Identities kept confidential: reporters' identities are kept confidential, and access to reports is limited to a few named people. Retaliation prohibited and punished: allegations of retaliation are investigated and acted on, and the outcomes are reported to the board or owners. Related practices reported weaker: retaliation risk assessed (partly in place). Answered by the respondent.	A reporter's identity leaks or they are penalised, and others stop reporting. Confidentiality and protection from retaliation decide whether anyone reports again; reporter confidentiality added after the review's isolated-weakness probe.	In place; related practice weaker C62
F25 S102	**An investigation is not independent or fair** Detection, speak-up and response QUESTION TO CLARIFY	Investigations are reported as always independent of the area concerned, and suspected fraud as investigated by line management or HR. Both can be right if HR or a manager from another area investigates; the answers do not say whether line managers ever investigate their own area. **Question:** When suspected fraud is investigated, does a line manager ever investigate a matter in the area they manage, and if so, how is independence achieved? Answered by the respondent.	The investigator is too close to the matter, or conclusions ignore other explanations.	Question to clarify C63

APPENDIX B

Fraud risk register

One risk for each scenario with a control reported as a gap or answers to settle. No likelihood, impact, priority or monetary value is assigned: MK has not yet approved a method for rating them.

REF	RISK	CURRENT POSITION	TREATMENT	OWNER
FR01 F03	**Deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk, because the answers about the control that stops it conflict.** These schemes defeat controls that rely on recognising a person or a document. Not rated.	The answers about AI-enabled fraud cannot both be right as given: one says AI-enabled schemes are assessed for every relevant process, the other that, for high-risk processes, the assessment does not ask how AI could be used against them.	C12 Controls tested against AI fakes; C10 Own AI tools in scope; C11 AI methods tested per process; C13 Simulated AI attack; C09 AI-enabled fraud covered	Fraud risk lead
FR02 F08	**A payment to a cause linked to a decision-maker buys influence, because recipients checked for links is partly in place.** Not rated.	Recipients checked for links: reported in place only in some areas, cases or periods.	C23 Recipients checked for links	Ethics lead
FR03 F11	**Patterns such as splitting or duplicates go unseen, because senior review of supplier payments is partly in place.** Not rated.	Senior review of supplier payments: reported in place only in some areas, cases or periods.	C35 Senior review of supplier payments; C34 Split orders monitored; C32 Data reviewed for unusual patterns; C33 Independent review of procurement	Finance lead
FR04 F15	**Unworked hours or overtime are approved and paid, because hours approved by supervisor is partly in place.** Not rated.	Hours approved by supervisor: reported in place only in some areas, cases or periods.	C43 Hours approved by supervisor	HR and payroll lead
FR05 F21	**Shrinkage and losses are written off without analysis, because losses tracked and reported is partly in place.** Not rated.	Losses tracked and reported: reported in place only in some areas, cases or periods.	C59 Losses tracked and reported	Finance lead

APPENDIX C

Control blueprint register

Each control once, with every scenario it serves, grouped by what is to be done and then in the method's order. "Reported today" is what the organisation answered; the target practice, activities, records, measure and failure response come from MK's draft control-content library (control-content-library-0.1), which is advisory content and not approved. The method's own wording and source references for each control are in the supporting workbook.

RESOLVE THE ANSWERS · 2

C09 AI-enabled fraud covered

FRAUD RISK LEAD · S14

REPORTED TODAY
AI-enabled schemes, including deepfake instructions, synthetic identities and generated documents, are assessed for every relevant process.

TARGET OPERATING PRACTICE
AI-enabled schemes, including deepfake instructions, synthetic identities and generated documents, are assessed for every relevant process in the fraud risk assessment.

IMPLEMENTATION ACTIVITIES

1. Establish which of the conflicting answers reflects how the process runs, and correct the record.
2. Add an assessment of AI-enabled schemes for every relevant process to the fraud risk assessment method and to the template it uses.
3. Apply it at the next assessment or update, starting with payments, changes to supplier and employee details, and customer onboarding.
4. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E09
Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M09
The assessment current at the end of the period shows AI-enabled schemes assessed for every process that moves money, changes master data or relies on recognising a person or a document.

IF IT FAILS
Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C11 AI methods tested per process

FRAUD RISK LEAD · S14

REPORTED TODAY
AI methods tested per process: reported as not in place.

TARGET OPERATING PRACTICE
For each high-risk process, the assessment asks how AI could be used against it, for example whether a cloned voice could pass a call-back check, and records the answer.

IMPLEMENTATION ACTIVITIES

1. Establish which of the conflicting answers reflects how the process runs, and correct the record.
2. Add a question, for each high-risk process, on how AI could be used against it to the fraud risk assessment method and to the template it uses.
3. Apply it at the next assessment or update, starting with processes that rely on a call-back, a signature or a document.
4. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E11
Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M11
The assessment current at the end of the period shows the question asked and answered for every high-risk process.

IF IT FAILS
Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

PUT IN PLACE · 4

C23 Recipients checked for links

ETHICS LEAD · S26

REPORTED TODAY
Recipients checked for links: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE
Before any donation or sponsorship is committed, the recipient is checked for links to public officials, customers' decision-makers and employees, and any link found is disclosed and approved.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for donations and sponsorships: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each donation or sponsorship.
3. Look back over donations and sponsorships from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E23
Donation approval file
Cycle: before each commitment

SUCCESS MEASURE · M23
Every donation or sponsorship in the period has a donation approval file showing the link checks completed and approved before money was committed.

IF IT FAILS
Where a donation or sponsorship went ahead without the check, complete the check at once and review anything paid or released before it was found.

C35 Senior review of supplier payments

FINANCE LEAD · S40

REPORTED TODAY

Senior review of supplier payments: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

Each month a senior manager who does not process payments reviews the list of supplier payments for unfamiliar suppliers, unusual amounts and changed bank details, and follows up each query.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in supplier payments and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E34

Monthly payment review
Cycle: monthly

SUCCESS MEASURE · M35

The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C43 Hours approved by supervisor

HR AND PAYROLL LEAD · S49

REPORTED TODAY

Hours approved by supervisor: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

Hours and overtime are approved by the employee's supervisor, against the roster or attendance record, before they are paid.

IMPLEMENTATION ACTIVITIES

1. Set who may approve timesheets, within what limits, and confirm that no one approves their own.
2. Set the time and attendance system so that the person who processes a timesheet cannot approve it.
3. Review a recent month of timesheets for approvals by the same person or after the event, and correct what allowed them.

RECORDS TO KEEP · E41

Timesheet approval record
Cycle: each pay run

SUCCESS MEASURE · M43

Every timesheet paid in the period was approved by the employee's supervisor, against the roster or attendance record, before payment.

IF IT FAILS

Have any timesheet approved by the person who processed it re-approved independently, and review that person's other timesheets for the period.

C59 Losses tracked and reported

FINANCE LEAD · S84

REPORTED TODAY

Losses tracked and reported: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

Losses of cash, stock and assets are tracked over time and by location, and reported to management each month with the actions taken.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in losses of cash, stock and assets and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E57

Loss report
Cycle: monthly

SUCCESS MEASURE · M59

The review of losses of cash, stock and assets ran monthly throughout the period, and every exception it raised was reported to management with the action taken.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

STRENGTHEN · 57

C01 Owner has authority across the organisation

CHIEF EXECUTIVE · S01

REPORTED TODAY

Owner has authority across the organisation: reported as not in place.

TARGET OPERATING PRACTICE

The executive accountable for fraud risk has written authority to require action from every area of the organisation, and a budget for fraud risk work approved each year.

IMPLEMENTATION ACTIVITIES

1. Set out the fraud risk owner's authority in writing, including what they can require of other areas and how disagreements are escalated.
2. Have the chief executive approve the mandate and the annual budget, and inform the executive team.
3. Review the mandate each year with the oversight body.

RECORDS TO KEEP · E01

Fraud risk mandate
Cycle: each year

SUCCESS MEASURE · M01

The mandate is current and approved, and every action the fraud risk owner required of another area in the period has a recorded response.

IF IT FAILS

Where an area does not act on a requirement of the fraud risk owner, escalate it to the chief executive and record the outcome.

C02 **Dedicated fraud capability**

CHIEF EXECUTIVE · S01

REPORTED TODAY

Dedicated fraud capability: reported in place only in some areas, cases or periods. (answered by Executive and governance)

TARGET OPERATING PRACTICE

A named fraud risk or forensic function, or a contracted external provider, is available to assess fraud risk and investigate suspected fraud, with its scope and response times agreed.

IMPLEMENTATION ACTIVITIES

1. Decide whether the capability is internal, external or shared, from the volume and nature of the fraud matters the organisation faces.
2. Appoint the people or contract the provider, with an agreed scope, response time and reporting line.
3. Review the arrangement each year against the matters it handled.

RECORDS TO KEEP · E02

Fraud capability arrangement
Cycle: each year

SUCCESS MEASURE · M02

The arrangement was in place throughout the period, and every matter referred to it was accepted within the agreed response time.

IF IT FAILS

Where a matter is not taken up in time, escalate it to the fraud risk owner, and review whether the arrangement needs to change.

C03 **Annual fraud action plan**

CHIEF FINANCIAL OFFICER · S01

REPORTED TODAY

Annual fraud action plan: reported in place only in some areas, cases or periods. (answered by Finance)

TARGET OPERATING PRACTICE

An annual fraud risk plan sets out the work for the year with its owners, dates and budget, and is approved by the oversight body.

IMPLEMENTATION ACTIVITIES

1. Draft the plan from the fraud risk assessment and the open matters in this report.
2. Have the oversight body approve the plan and its budget.
3. Report progress against the plan at each oversight meeting.

RECORDS TO KEEP · E03

Annual fraud risk plan
Cycle: each year

SUCCESS MEASURE · M03

The plan for the year was approved, and progress against it was reported at each oversight meeting in the period.

IF IT FAILS

Where planned work falls behind, report the reason and a revised date to the oversight body.

C04 **Qualified fraud leads**

CHIEF FINANCIAL OFFICER · S01

REPORTED TODAY

Qualified fraud leads: reported in place only in some areas, cases or periods. (answered by Finance)

TARGET OPERATING PRACTICE

The people who lead fraud risk work hold, or are working towards, recognised fraud training or qualifications, such as the CFE, and complete continuing education each year.

IMPLEMENTATION ACTIVITIES

1. Set the training or qualification expected of each person who leads fraud risk work.
2. Agree a development plan, with time and budget, for each person who does not yet meet it.
3. Record continuing education each year.

RECORDS TO KEEP · E04

Fraud training record
Cycle: each year

SUCCESS MEASURE · M04

Every person leading fraud risk work meets the agreed standard or is on a development plan that is on track.

IF IT FAILS

Where a development plan falls behind, agree a revised plan or bring in qualified external support.

C05 **Risks described as schemes**

FRAUD RISK LEAD · S13

REPORTED TODAY

Some risks describe a scheme, but most remain general. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Every fraud risk is described as a specific scheme, stating who could commit it, how, and in which process.

IMPLEMENTATION ACTIVITIES

1. Add a description of each risk as a scheme, with its perpetrator, method and process to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with the processes that move money or stock.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E05

Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M05

The assessment current at the end of the period shows every risk described with its perpetrator, method and process.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C06 **Processes walked through**

FRAUD RISK LEAD · S13

REPORTED TODAY

Processes walked through: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The assessment walks through each high-risk process step by step with the people who run it, and records where fraud could occur at each step.

IMPLEMENTATION ACTIVITIES

1. Add a step-by-step walkthrough of each high-risk process to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with payments, payroll and procurement.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E06

Process walkthrough notes
Cycle: at each assessment

SUCCESS MEASURE · M06

The assessment current at the end of the period shows a recorded walkthrough for every high-risk process.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C07 **Management owns the results**

FRAUD RISK LEAD · S13

REPORTED TODAY

Management has not seen or accepted the results. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Management formally accepts the results of the fraud risk assessment, and every significant risk has a named owner who has agreed to it.

IMPLEMENTATION ACTIVITIES

1. Present the assessment to the executive team for formal acceptance.
2. Assign each significant risk to a named owner, and record the owner's agreement.
3. Repeat the acceptance after each full assessment or major update.

RECORDS TO KEEP · E07

Assessment acceptance record
Cycle: after each assessment

SUCCESS MEASURE · M07

The assessment current at the end of the period shows formal acceptance by management and an agreed owner for every significant risk.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C08 **Process owners take part**

FRAUD RISK LEAD · S13

REPORTED TODAY

Process owners take part: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The people who run each high-risk process take part in the assessment, through workshops or interviews, and their input is recorded.

IMPLEMENTATION ACTIVITIES

1. Add participation by the people who run each high-risk process to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with the processes that move money or stock.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E08

Assessment participation record
Cycle: at each assessment

SUCCESS MEASURE · M08

The assessment current at the end of the period shows participation by the people who run every high-risk process.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C10 **Own AI tools in scope**

FRAUD RISK LEAD · S14

REPORTED TODAY

Own AI tools in scope: reported in place only in some areas, cases or periods. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The fraud risk assessment covers how the organisation's own AI tools, such as chatbots, assistants and automated approvals, could be manipulated or misused, and names a control for each.

IMPLEMENTATION ACTIVITIES

1. Add the misuse of the organisation's own AI tools to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with tools that can approve, pay or change records.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E10

Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M10

The assessment current at the end of the period shows every AI tool in use listed with its misuse risks and a named control.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C12 Controls tested against AI fakes

FRAUD RISK LEAD · S14

REPORTED TODAY

Controls tested against AI fakes: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Each control that relies on recognising a voice, face, signature or document is assessed for whether an AI-generated fake could defeat it, and those that could are redesigned.

IMPLEMENTATION ACTIVITIES

1. Add an assessment of each recognition-based control against AI-generated fakes to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with call-back and identity checks.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E12

Control assessment
Cycle: at each assessment and update

SUCCESS MEASURE · M12

The assessment current at the end of the period shows every control that relies on recognition assessed, with any change needed made or scheduled.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C13 Simulated AI attack

FRAUD RISK LEAD · S14

REPORTED TODAY

Simulated AI attack: partly in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The organisation's verification controls are tested at least once a year with a simulated AI attack, such as a staged deepfake call to the finance team, and the results are acted on.

IMPLEMENTATION ACTIVITIES

1. Choose the controls to test, starting with call-backs on payments and on changes to bank details.
2. Run a staged deepfake call or message with the chief executive's agreement, and record how it was handled.
3. Agree actions from the results, and repeat the test each year.

RECORDS TO KEEP · E13

Simulation record
Cycle: at least once a year

SUCCESS MEASURE · M13

In the period, a simulated AI attack was run against the verification controls, and every action arising from it is complete or on schedule.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C14 Likelihood and impact rated

FRAUD RISK LEAD · S17

REPORTED TODAY

Likelihood and impact rated: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Each fraud risk is rated for how likely it is and how much harm it could cause, on a scale management has approved, and the rating is compared with the approved tolerance.

IMPLEMENTATION ACTIVITIES

1. Add a likelihood and impact rating for each risk to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with the processes that move money or stock.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E14

Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M14

The assessment current at the end of the period shows a likelihood and impact rating for every risk on the approved scale.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C15 Assessment documented

FRAUD RISK LEAD · S18

REPORTED TODAY

Assessment documented: reported in place only in some areas, cases or periods. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The fraud risk assessment is documented in a register that shows, for each risk, its rating, the controls relied on, the decision taken and the owner.

IMPLEMENTATION ACTIVITIES

1. Add a register showing each risk's rating, controls, decision and owner to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with the processes that move money or stock.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E15

Fraud risk register
Cycle: at each assessment and update

SUCCESS MEASURE · M15

The assessment current at the end of the period shows every risk recorded with its rating, controls, decision and owner.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C16 **Owners know their risks**

FRAUD RISK LEAD · S18

REPORTED TODAY

Owners know their risks: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

The people who run each process receive the fraud risks recorded for their area after each assessment, and confirm that they understand them and the controls they operate.

IMPLEMENTATION ACTIVITIES

1. Send each process owner the risks and controls recorded for their area after each assessment.
2. Ask each owner to confirm them, or to correct them, within a set period.
3. Follow up owners who have not responded, and feed corrections into the register.

RECORDS TO KEEP · E16

Process owner confirmations
Cycle: after each assessment

SUCCESS MEASURE · M16

Every process owner in scope received the risks for their area and confirmed them, or has an approved exception.

IF IT FAILS

Follow up owners who do not respond through their executive, and correct the register where an owner disagrees with it.

C17 **Leaders trained on their duties**

HR AND PAYROLL LEAD · S19

REPORTED TODAY

Leaders trained on their duties: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Directors and senior managers are trained on their personal duties, including reporting corruption under section 34 of the Prevention and Combating of Corrupt Activities Act and the organisation's liability for bribery, on appointment and every two years.

IMPLEMENTATION ACTIVITIES

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion each year, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

RECORDS TO KEEP · E17

Leadership training record
Cycle: each year

SUCCESS MEASURE · M17

Every director and senior manager completed the training on appointment and within the last two years, and completion is recorded.

IF IT FAILS

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

C18 **High-risk activities identified**

LEGAL AND COMPLIANCE LEAD · S19

REPORTED TODAY

The main high-risk activities are identified, and some have extra controls.

TARGET OPERATING PRACTICE

All activities with high bribery risk, such as winning work, licences, customs and inspections, are identified and have specific extra controls.

IMPLEMENTATION ACTIVITIES

1. Add the identification of activities with high bribery risk and their extra controls to the fraud risk assessment method and to the template it uses.
2. Apply it at the next assessment or update, starting with winning work and dealings with public officials.
3. Have the person who signs off the assessment confirm that it meets the requirement.

RECORDS TO KEEP · E18

Bribery risk assessment
Cycle: at each assessment and update

SUCCESS MEASURE · M18

The assessment current at the end of the period shows every high-risk activity identified with its extra controls.

IF IT FAILS

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

C19 **Training on joining**

HR AND PAYROLL LEAD · S25

REPORTED TODAY

Training on joining: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Every new employee completes fraud and ethics training in their first month, covering the code of conduct, how to report concerns and the schemes relevant to their role.

IMPLEMENTATION ACTIVITIES

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion monthly, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

RECORDS TO KEEP · E19

Training completion record
Cycle: monthly

SUCCESS MEASURE · M19

Every new employee completed the training within their first month, and completion is recorded.

IF IT FAILS

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

C20 **Written code of conduct**

HR AND PAYROLL LEAD · S25

REPORTED TODAY

Written code of conduct: not in place. (answered by HR and payroll)

TARGET OPERATING PRACTICE

A written code of conduct, approved by the board, council or owners, sets out expected behaviour on fraud, bribery, conflicts of interest and gifts, and is reviewed every two years.

IMPLEMENTATION ACTIVITIES

1. Draft or update the code, covering fraud, bribery, conflicts of interest and gifts.
2. Have the board, council or owners approve it.
3. Communicate it to all staff, and review it every two years.

RECORDS TO KEEP · E20

Code of conduct
Cycle: every two years

SUCCESS MEASURE · M20

The current code of conduct is approved, was reviewed within the last two years and has been communicated to all staff.

IF IT FAILS

Bring the code of conduct up to date, and check whether anything was missed while it was out of date.

C21 **Programme independently reviewed**

ETHICS LEAD · S25

REPORTED TODAY

Programme independently reviewed: reported as not in place. (answered by Legal, compliance and ethics)

TARGET OPERATING PRACTICE

Internal audit or an independent reviewer assesses whether the ethics and anti-bribery programme works at least every three years, and management acts on the findings.

IMPLEMENTATION ACTIVITIES

1. Include the ethics and anti-bribery programme in the internal audit plan or appoint an external reviewer, with a scope that covers the fraud schemes concerned.
2. Agree with the reviewer what will be tested and how findings will be reported.
3. Track each finding to closure, and report progress to the oversight body.

RECORDS TO KEEP · E21

Review report
Cycle: within the last three years

SUCCESS MEASURE · M21

A review of the ethics and anti-bribery programme was completed within the last three years, and its findings are closed or on schedule.

IF IT FAILS

Where findings are overdue, escalate them to the oversight body with the reason and a new date.

C22 **Trends reported upward**

ETHICS LEAD · S25

REPORTED TODAY

Trends reported upward: reported as not in place. (answered by Legal, compliance and ethics)

TARGET OPERATING PRACTICE

Trends in declarations of interest, gifts and ethics breaches are reported to the board, council, social and ethics committee or owners at least twice a year.

IMPLEMENTATION ACTIVITIES

1. Bring declarations, gifts and breaches into one register.
2. Prepare a trend report for the oversight body at least twice a year.
3. Record the oversight body's response to each matter raised.

RECORDS TO KEEP · E22

Ethics trend report
Cycle: at least twice a year

SUCCESS MEASURE · M22

A trend report was presented to the oversight body at least twice in the period, and each matter it raised has a recorded response.

IF IT FAILS

Where a matter raised has no response, carry it to the next meeting of the oversight body as an open item.

C24 **New supplier approved by another person**

PROCUREMENT LEAD · S29

REPORTED TODAY

New supplier approved by another person: reported as not in place.

TARGET OPERATING PRACTICE

A new supplier becomes active only when someone other than the person who captured it has approved it.

IMPLEMENTATION ACTIVITIES

1. Set who may approve new suppliers, within what limits, and confirm that no one approves their own.
2. Set the supplier master file so that the person who processes a new supplier cannot approve it.
3. Review a recent month of new suppliers for approvals by the same person or after the event, and correct what allowed them.

RECORDS TO KEEP · E24

Supplier approval log
Cycle: before each new supplier becomes active

SUCCESS MEASURE · M24

Every new supplier in the period was approved by someone other than the person who processed it, before it became active.

IF IT FAILS

Have any new supplier approved by the person who processed it re-approved independently, and review that person's other new suppliers for the period.

C25 Directors identified

PROCUREMENT LEAD · S29

REPORTED TODAY

Owners are identified only when something raises a concern. (answered by Procurement)

TARGET OPERATING PRACTICE

The directors and owners of every new supplier, including those behind holding companies, are identified from an independent source such as CIPC.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for new suppliers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each new supplier.
3. Look back over new suppliers from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E25

Supplier set-up file
Cycle: before each new supplier is first paid

SUCCESS MEASURE · M25

Every new supplier in the period has a supplier set-up file showing directors and owners identified from an independent source before the first payment.

IF IT FAILS

Where a new supplier went ahead without the check, complete the check at once and review anything paid or released before it was found.

C26 Directors compared with staff

PROCUREMENT LEAD · S29

REPORTED TODAY

Directors compared with staff: reported as not in place. (answered by Procurement)

TARGET OPERATING PRACTICE

Supplier directors, owners, addresses and bank accounts are compared with employee records when a supplier is set up and at least once a year, and every match is investigated.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in supplier and employee records and the report, query or alert that finds them.
2. Name who reviews the output at set-up and at least once a year and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E26

Supplier and employee match report
Cycle: at set-up and at least once a year

SUCCESS MEASURE · M26

Every new supplier was compared with employee records at set-up, the whole supplier file was compared at least once in the year, and every match has a recorded conclusion.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C27 Suppliers re-checked

PROCUREMENT LEAD · S29

REPORTED TODAY

Suppliers re-checked: reported as set out or agreed but not yet working in practice. (answered by Procurement)

TARGET OPERATING PRACTICE

Existing suppliers are re-checked against the set-up checks at least every two years, and the highest-value suppliers each year.

IMPLEMENTATION ACTIVITIES

1. Set the re-check cycle by supplier value and risk.
2. Repeat the set-up checks for each supplier due, starting with the highest-value suppliers.
3. Record each result, and verify any change found before the next payment.

RECORDS TO KEEP · E27

Supplier re-check log
Cycle: each year

SUCCESS MEASURE · M27

Every supplier due for a re-check in the period was re-checked, and every change found was verified before the next payment.

IF IT FAILS

Where a re-check finds a change that was not verified, hold payments to that supplier until it is verified.

C28 Dormant suppliers deactivated

PROCUREMENT LEAD · S29

REPORTED TODAY

Dormant suppliers deactivated: reported as not in place. (answered by Procurement)

TARGET OPERATING PRACTICE

Suppliers not used for a set period, such as twelve months, are deactivated, and reactivating one requires the full set-up checks.

IMPLEMENTATION ACTIVITIES

1. Set the period after which an unused supplier is deactivated.
2. Run the dormant supplier report each quarter, and deactivate the suppliers it lists.
3. Require the full set-up checks before any supplier is reactivated.

RECORDS TO KEEP · E28

Dormant supplier report
Cycle: each quarter

SUCCESS MEASURE · M28

The dormant supplier report was run each quarter in the period, and every supplier unused for the set period is deactivated.

IF IT FAILS

Bring the dormant supplier report up to date, and check whether anything was missed while it was out of date.

C29 **Approved order before commitment**

PROCUREMENT LEAD · S33

REPORTED TODAY

Most purchases are approved before commitment, through a purchase order or another record. (answered by Procurement)

TARGET OPERATING PRACTICE

Every purchase is approved by someone with the authority to do so before the organisation commits to it, and the approval is recorded.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for purchases: what is checked, by whom, and who may approve an exception.
2. Set the purchasing system so that no purchase proceeds until the check is recorded as passed.
3. Look back over purchases from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E29

Purchase order or approval record
Cycle: before each commitment

SUCCESS MEASURE · M29

Every purchase in the period has a purchase order or approval record showing approval by an authorised person dated before the commitment.

IF IT FAILS

Where a purchase went ahead without the check, complete the check at once and review anything paid or released before it was found.

C30 **Receipt recorded before payment**

OPERATIONS LEAD · S33

REPORTED TODAY

Receipt is recorded for most deliveries, but not always before payment. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Receipt of goods is always recorded before the related invoice is paid.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for goods invoices: what is checked, by whom, and who may approve an exception.
2. Set the receiving system so that no goods invoice proceeds until the check is recorded as passed.
3. Look back over goods invoices from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E30

Goods received note
Cycle: before each payment

SUCCESS MEASURE · M30

Every goods invoice in the period has a goods received note showing receipt recorded before the invoice was paid.

IF IT FAILS

Where a goods invoice went ahead without the check, complete the check at once and review anything paid or released before it was found.

C31 **Services confirmed**

OPERATIONS LEAD · S33

REPORTED TODAY

Services confirmed: reported as not in place. (answered by Operations and sales)

TARGET OPERATING PRACTICE

For every service, the person who received it confirms in writing that it was delivered as ordered before the invoice is paid.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for service invoices: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each service invoice.
3. Look back over service invoices from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E31

Service delivery confirmation
Cycle: before each payment

SUCCESS MEASURE · M31

Every service invoice in the period has a service delivery confirmation showing written confirmation of delivery from the person who received the service before payment.

IF IT FAILS

Where a service invoice went ahead without the check, complete the check at once and review anything paid or released before it was found.

C32 **Data reviewed for unusual patterns**

INTERNAL AUDIT · S40

REPORTED TODAY

Data reviewed for unusual patterns: reported as not in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Procurement and supplier payment data is reviewed monthly, by someone independent of buying and paying, for patterns such as split orders, duplicate invoices, new suppliers paid quickly and payments just below approval limits.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in procurement and supplier payment data and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E32

Monthly exception review
Cycle: monthly

SUCCESS MEASURE · M32

The review of procurement and supplier payment data ran monthly throughout the period, and every exception it raised has a recorded conclusion.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C33 **Independent review of procurement**

INTERNAL AUDIT · S40

REPORTED TODAY

Independent review of procurement: partly in place. (answered by Risk and investigations)

TARGET OPERATING PRACTICE

Internal audit or an external reviewer examines procurement at least every two years, including supplier set-up, competition and payment, and management acts on the findings.

IMPLEMENTATION ACTIVITIES

1. Include procurement in the internal audit plan or appoint an external reviewer, with a scope that covers the fraud schemes concerned.
2. Agree with the reviewer what will be tested and how findings will be reported.
3. Track each finding to closure, and report progress to the oversight body.

RECORDS TO KEEP · E21

Review report
Cycle: within the last two years

SUCCESS MEASURE · M33

A review of procurement was completed within the last two years, and its findings are closed or on schedule.

IF IT FAILS

Where findings are overdue, escalate them to the oversight body with the reason and a new date.

C34 **Split orders monitored**

PROCUREMENT LEAD · S40

REPORTED TODAY

Split orders monitored: reported as set out or agreed but not yet working in practice. (answered by Procurement)

TARGET OPERATING PRACTICE

Orders to the same supplier are reviewed monthly for several smaller orders that together exceed an approval limit, and each instance is followed up.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in orders to the same supplier and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E33

Split order report
Cycle: monthly

SUCCESS MEASURE · M34

The review of orders to the same supplier ran monthly throughout the period, and every exception it raised has a recorded conclusion.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C36 **Contract register**

PROCUREMENT LEAD · S41

REPORTED TODAY

Contract register: reported as not in place. (answered by Procurement)

TARGET OPERATING PRACTICE

A register lists every active supplier contract with its value, term, owner and renewal date, and is kept current.

IMPLEMENTATION ACTIVITIES

1. Create the contract register with the fields it needs, and name who maintains it.
2. Populate it from current information, and resolve gaps with the people responsible.
3. Review it each quarter and whenever a contract is signed, varied or ends.

RECORDS TO KEEP · E35

Contract register
Cycle: each quarter

SUCCESS MEASURE · M36

The contract register was reviewed as planned in the period, and every active contract is recorded with its owner and dates.

IF IT FAILS

Bring the contract register up to date, and check whether anything was missed while it was out of date.

C37 **Large variations escalated**

PROCUREMENT LEAD · S41

REPORTED TODAY

Large variations escalated: reported as set out or agreed but not yet working in practice. (answered by Procurement)

TARGET OPERATING PRACTICE

Variations above a set percentage of the original value are approved at a higher level than the original award.

IMPLEMENTATION ACTIVITIES

1. Set who may approve large variations, within what limits, and confirm that no one approves their own.
2. Record the approver on each large variation, and check that it is never the person who processed it.
3. Review a recent month of large variations for approvals by the same person or after the event, and correct what allowed them.

RECORDS TO KEEP · E36

Variation approval record
Cycle: before each large variation proceeds

SUCCESS MEASURE · M37

Every large variation in the period was approved by someone other than the person who processed it, at the higher level before the work went ahead.

IF IT FAILS

Have any large variation approved by the person who processed it re-approved independently, and review that person's other large variations for the period.

C38 **Written supplier contracts**

PROCUREMENT LEAD · S41

REPORTED TODAY

Written supplier contracts: reported in place only in some areas, cases or periods. (answered by Procurement)

TARGET OPERATING PRACTICE

Ongoing or significant supplier relationships are governed by signed written contracts that set out price, scope, terms and audit rights.

IMPLEMENTATION ACTIVITIES

1. Set the value or duration above which a signed contract is required.
2. Identify suppliers above it without a signed contract, and put contracts in place.
3. Check the contract register each quarter for new suppliers above the threshold.

RECORDS TO KEEP · E37

Contract register
Cycle: each quarter

SUCCESS MEASURE · M38

The contract register was reviewed as planned in the period, and every ongoing or significant supplier has a signed contract.

IF IT FAILS

Bring the contract register up to date, and check whether anything was missed while it was out of date.

C39 **Bank change report reviewed**

HR AND PAYROLL LEAD · S42

REPORTED TODAY

Bank change report reviewed: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

Before each pay run, someone who cannot make bank detail changes reviews a report of them and traces each change to its confirmation.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in employee bank detail changes and the report, query or alert that finds them.
2. Name who reviews the output before each pay run and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E38

Bank change report review
Cycle: before each pay run

SUCCESS MEASURE · M39

Before every pay run in the period, the report was reviewed and every bank detail change traced to its confirmation.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C40 **New employee checked by another person**

HR AND PAYROLL LEAD · S43

REPORTED TODAY

The person who captures the record checks it themselves. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Every new payroll record is checked against a signed appointment by someone other than the person who captured it, before the first pay run.

IMPLEMENTATION ACTIVITIES

1. Set who may approve new payroll records, within what limits, and confirm that no one approves their own.
2. Set the payroll system so that the person who processes a new payroll record cannot approve it.
3. Review a recent month of new payroll records for approvals by the same person or after the event, and correct what allowed them.

RECORDS TO KEEP · E39

New starter file
Cycle: before each first pay run

SUCCESS MEASURE · M40

Every new payroll record in the period was approved by someone other than the person who processed it, against a signed appointment before the first pay run.

IF IT FAILS

Have any new payroll record approved by the person who processed it re-approved independently, and review that person's other new payroll records for the period.

C41 **Payroll data analysed**

HR AND PAYROLL LEAD · S43

REPORTED TODAY

Payroll data analysed: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Payroll data is analysed each pay run for unusual patterns, such as shared bank accounts, employees with no leave or tax record and pay outside the scale, and each exception is followed up.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in payroll data and the report, query or alert that finds them.
2. Name who reviews the output each pay run and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E40

Payroll analytics review
Cycle: each pay run

SUCCESS MEASURE · M41

The review of payroll data ran each pay run throughout the period, and every exception it raised has a recorded conclusion.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C42 Independent review of payroll

HR AND PAYROLL LEAD · S43

REPORTED TODAY

Independent review of payroll: partly in place. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Internal audit or an external reviewer examines payroll at least every two years, including starters, leavers, changes and payments, and management acts on the findings.

IMPLEMENTATION ACTIVITIES

1. Include payroll in the internal audit plan or appoint an external reviewer, with a scope that covers the fraud schemes concerned.
2. Agree with the reviewer what will be tested and how findings will be reported.
3. Track each finding to closure, and report progress to the oversight body.

RECORDS TO KEEP · E21

Review report
Cycle: within the last two years

SUCCESS MEASURE · M42

A review of payroll was completed within the last two years, and its findings are closed or on schedule.

IF IT FAILS

Where findings are overdue, escalate them to the oversight body with the reason and a new date.

C44 High-risk roles identified

HR AND PAYROLL LEAD · S52

REPORTED TODAY

Managers know informally which roles are risky. (answered by HR and payroll)

TARGET OPERATING PRACTICE

A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.

IMPLEMENTATION ACTIVITIES

1. Create the list of high-risk roles with the fields it needs, and name who maintains it.
2. Populate it from current information, and resolve gaps with the people responsible.
3. Review it each year and whenever roles or system access change.

RECORDS TO KEEP · E42

List of high-risk roles
Cycle: each year

SUCCESS MEASURE · M44

The list of high-risk roles was reviewed as planned in the period, and every role that can move money, change master data or manage system access is on it.

IF IT FAILS

Bring the list of high-risk roles up to date, and check whether anything was missed while it was out of date.

C45 No conflicting duties when covering

HR AND PAYROLL LEAD · S52

REPORTED TODAY

No conflicting duties when covering: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

TARGET OPERATING PRACTICE

People in high-risk roles never hold conflicting duties, including temporarily when covering for colleagues; cover arrangements are approved and checked against the list of conflicting duties.

IMPLEMENTATION ACTIVITIES

1. List who holds the duties concerned, and remove any combination that lets one person hold conflicting duties, including while covering for a colleague.
2. Set system access settings so that the combination cannot be granted again without recorded approval.
3. Review the combinations at least once a year and whenever roles change, including temporary cover.

RECORDS TO KEEP · E43

Cover arrangement log
Cycle: whenever cover is arranged

SUCCESS MEASURE · M45

The review for the period found no one able to hold conflicting duties, including while covering for a colleague, and every cover arrangement was checked and approved.

IF IT FAILS

Remove the combination, review the cover arrangements handled while it existed, and record the outcome.

C46 Concerns raised fairly

HR AND PAYROLL LEAD · S52

REPORTED TODAY

Concerns raised fairly: reported as not in place. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Managers have a defined, confidential route to raise and escalate concerns about an employee's behaviour, without making accusations, and each concern is assessed and recorded.

IMPLEMENTATION ACTIVITIES

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

RECORDS TO KEEP · E44

Concerns log
Cycle: each year

SUCCESS MEASURE · M46

In the period, every concern raised was assessed and its outcome recorded.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C47 Support for financial pressure

HR AND PAYROLL LEAD · S52

REPORTED TODAY

Support for financial pressure: reported as not in place. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Employees in financial difficulty can use confidential support, such as financial wellness or an employee assistance programme, and staff know how to reach it.

IMPLEMENTATION ACTIVITIES

1. Choose the support offered, internally or through a provider.
2. Tell every employee how to reach it confidentially, at induction and each year.
3. Review its use each year, in aggregate only, and adjust the support.

RECORDS TO KEEP · E45

Support programme record
Cycle: each year

SUCCESS MEASURE · M47

Every employee was told how to reach the support during the year, and the support was available throughout the period.

IF IT FAILS

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

C48 Capture and authorise separated

FINANCE LEAD · S53

REPORTED TODAY

Users can capture payments, load beneficiaries and authorise.

TARGET OPERATING PRACTICE

Banking platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.

IMPLEMENTATION ACTIVITIES

1. List who holds the duties concerned, and remove any combination that lets one person capture a payment or load a beneficiary and also authorise the payment.
2. Set the banking platform roles so that the combination cannot be granted again without recorded approval.
3. Review the combinations at least once a year and whenever roles change, including temporary cover.

RECORDS TO KEEP · E46

Banking platform role report
Cycle: each quarter

SUCCESS MEASURE · M48

The review for the period found no one able to capture a payment or load a beneficiary and also authorise the payment, other than approved and recorded exceptions.

IF IT FAILS

Remove the combination, review the payments handled while it existed, and record the outcome.

C49 Refunds to the original source

COMMERCIAL AND CUSTOMER LEAD · S65

REPORTED TODAY

Refunds are paid wherever the customer asks.

TARGET OPERATING PRACTICE

Every refund goes to the original payment method, or to a customer account verified before payment.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for refunds: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each refund.
3. Look back over refunds from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E47

Refund record
Cycle: before each refund is paid

SUCCESS MEASURE · M49

Every refund in the period has a refund record showing payment to the original method, or to an account verified before payment.

IF IT FAILS

Where a refund went ahead without the check, complete the check at once and review anything paid or released before it was found.

C50 Dual control at hand-overs

OPERATIONS LEAD · S75

REPORTED TODAY

Cash is counted at some handovers, such as at the end of the day, but not at shift changes. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Whenever cash changes hands, two people count it, record it and sign for it.

IMPLEMENTATION ACTIVITIES

1. Set the points where cash changes hands, such as shift changes and till clearances, and require two people at each.
2. Use a hand-over sheet that both people sign.
3. Check the sheets daily for a missing signature or a difference.

RECORDS TO KEEP · E48

Cash hand-over sheet
Cycle: at each hand-over

SUCCESS MEASURE · M50

The review for the period found no one able to take or hand over cash without a second person counting it, and every hand-over sheet carries two signatures.

IF IT FAILS

Remove the combination, review the cash hand-overs handled while it existed, and record the outcome.

C51 Deposits reconciled independently

OPERATIONS LEAD · S75

REPORTED TODAY

Deposits are checked against the statement occasionally. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Every deposit and collection is reconciled to the bank statement by someone who does not handle the cash, using statements obtained directly from the bank.

IMPLEMENTATION ACTIVITIES

1. Set the reconciliation: what is compared, how often (daily), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

RECORDS TO KEEP · E49

Deposit reconciliation
Cycle: daily

SUCCESS MEASURE · M51

Every deposit reconciliation due in the period was completed and reviewed, and every difference has a recorded explanation.

IF IT FAILS

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

C52 Takings checked against an independent record

OPERATIONS LEAD · S75

REPORTED TODAY

Takings checked against an independent record: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

Takings are reconciled to an independent record of activity, such as till rolls, ticket numbers, meter readings or occupancy, and not only to what the cashier records.

IMPLEMENTATION ACTIVITIES

1. Set the reconciliation: what is compared, how often (daily), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

RECORDS TO KEEP · E50

Takings-to-activity reconciliation
Cycle: daily

SUCCESS MEASURE · M52

Every takings-to-activity reconciliation due in the period was completed and reviewed, and every difference has a recorded explanation.

IF IT FAILS

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

C53 Store access limited

OPERATIONS LEAD · S76

REPORTED TODAY

Store access limited: reported as not in place. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Access to stores and warehouses is limited to authorised people, and every visitor and contractor is recorded on entry and exit.

IMPLEMENTATION ACTIVITIES

1. Set who is authorised to enter each store, and control entry with locks or access cards.
2. Record every visitor and contractor on entry and exit.
3. Review the authorised list and the visitor record monthly.

RECORDS TO KEEP · E51

Store access register
Cycle: monthly

SUCCESS MEASURE · M53

At the end of the period, the store access register shows access limited to authorised people at every store, with every visitor recorded, and any exception is approved and recorded.

IF IT FAILS

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

C54 Issues against approved requests

OPERATIONS LEAD · S76

REPORTED TODAY

Issues against approved requests: reported as not in place. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Every stock issue or transfer is recorded against an approved requisition or order before the goods leave the store.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for stock issues and transfers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each stock issue or transfer.
3. Look back over stock issues and transfers from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E52

Issue record
Cycle: before goods leave the store

SUCCESS MEASURE · M54

Every stock issue or transfer in the period has an issue record showing an approved requisition or order before the goods left.

IF IT FAILS

Where a stock issue or transfer went ahead without the check, complete the check at once and review anything paid or released before it was found.

C55 **Custody separated from records**

OPERATIONS LEAD · S76

REPORTED TODAY

Duties are separated on paper, but storekeepers can still change the records. (answered by Operations and sales)

TARGET OPERATING PRACTICE

At every store, the people who keep stock records are different from those who hold the stock, and system access enforces this.

IMPLEMENTATION ACTIVITIES

1. List who holds the duties concerned, and remove any combination that lets one person hold stock and also change the stock records.
2. Set stock system access so that the combination cannot be granted again without recorded approval.
3. Review the combinations at least once a year and whenever roles change, including temporary cover.

RECORDS TO KEEP · E53

Stock system access list
Cycle: each quarter

SUCCESS MEASURE · M55

The review for the period found no one able to hold stock and also change the stock records, other than approved and recorded exceptions.

IF IT FAILS

Remove the combination, review the stock adjustments handled while it existed, and record the outcome.

C56 **High-value items secured**

OPERATIONS LEAD · S76

REPORTED TODAY

High-value items secured: reported as set out or agreed but not yet working in practice. (answered by Operations and sales)

TARGET OPERATING PRACTICE

High-value or easily resold items are kept in a secure area with extra controls, such as cages, seals or serial number tracking, and access to the area is recorded.

IMPLEMENTATION ACTIVITIES

1. Identify the high-value or easily resold lines, and set the extra controls for each.
2. Move them into a secure area with recorded access.
3. Count them more often than other stock, and review access to the area monthly.

RECORDS TO KEEP · E54

Secure area register
Cycle: monthly

SUCCESS MEASURE · M56

At the end of the period, the secure area register shows every high-value line held in the secure area with its controls applied, and any exception is approved and recorded.

IF IT FAILS

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

C57 **Differences explained before adjusting**

FINANCE LEAD · S76

REPORTED TODAY

Differences explained before adjusting: reported as not in place. (answered by Finance)

TARGET OPERATING PRACTICE

Every count difference is investigated and explained, and the adjustment approved by finance, before the stock record is changed.

IMPLEMENTATION ACTIVITIES

1. Set out the check in the procedure for stock adjustments: what is checked, by whom, and who may approve an exception.
2. Set the stock system so that no stock adjustment proceeds until the check is recorded as passed.
3. Look back over stock adjustments from the last twelve months, and follow up any that would not have passed the check.

RECORDS TO KEEP · E55

Adjustment record
Cycle: after each count

SUCCESS MEASURE · M57

Every stock adjustment in the period has an adjustment record showing an investigation and an approval before the record was changed.

IF IT FAILS

Where a stock adjustment went ahead without the check, complete the check at once and review anything paid or released before it was found.

C58 **How stock is recorded**

OPERATIONS LEAD · S76

REPORTED TODAY

How stock is recorded: it is not formally recorded. (answered by Operations and sales)

TARGET OPERATING PRACTICE

Stock is recorded in an inventory or ERP system, with movements recorded as they happen, so that each count can be compared with an expected quantity.

IMPLEMENTATION ACTIVITIES

1. Choose the system or structured record for stock, proportionate to its value.
2. Record opening quantities and every receipt, issue and adjustment as it happens.
3. Compare the record with each count, and investigate the differences.

RECORDS TO KEEP · E56

Stock record
Cycle: at each count

SUCCESS MEASURE · M58

Every stock line is held on the stock record with its movements, and each count in the period was compared with it.

IF IT FAILS

Bring the stock record up to date, and check whether anything was missed while it was out of date.

C60 **Mailbox rules and odd logins alerted**

IT LEAD · S85

REPORTED TODAY

Mailbox rules and odd logins alerted: reported as not in place.

TARGET OPERATING PRACTICE

New forwarding or inbox rules, and logins from unusual locations, raise alerts that IT reviews the same day.

IMPLEMENTATION ACTIVITIES

1. Define the patterns to look for in mailbox rule and login alerts and the report, query or alert that finds them.
2. Name who reviews the output daily and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

RECORDS TO KEEP · E58

Alert log
Cycle: daily

SUCCESS MEASURE · M60

Every alert in the period was reviewed the same day and has a recorded outcome.

IF IT FAILS

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

C61 **Speak-up channel**

INVESTIGATIONS LEAD · S99

REPORTED TODAY

Speak-up channel: only informally, such as telling a manager.

TARGET OPERATING PRACTICE

A speak-up channel, preferably run by an independent provider, lets employees and others report concerns confidentially or anonymously, and every report is assessed and tracked.

IMPLEMENTATION ACTIVITIES

1. Choose the channel, independent or internal, and how reports reach someone outside the reporter's line.
2. Publicise it to employees, suppliers and others who may need it.
3. Track each report to a recorded outcome, and report trends to the oversight body.

RECORDS TO KEEP · E59

Speak-up log
Cycle: each year

SUCCESS MEASURE · M61

In the period, every report received was assessed and tracked to a recorded outcome.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C62 **Retaliation risk assessed**

ETHICS LEAD · S100

REPORTED TODAY

Retaliation risk assessed: reported in place only in some areas, cases or periods.

TARGET OPERATING PRACTICE

When a report is received, the reporter's risk of retaliation or harm is assessed, and protective steps are taken where needed.

IMPLEMENTATION ACTIVITIES

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

RECORDS TO KEEP · E60

Reporter protection log
Cycle: each year

SUCCESS MEASURE · M62

In the period, every report received had the reporter's risk assessed, with protective steps recorded where needed.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C63 **Who investigates**

INVESTIGATIONS LEAD · S102

REPORTED TODAY

Who investigates: line management or HR.

TARGET OPERATING PRACTICE

Responsibility for investigating suspected fraud rests with a dedicated internal team or an appointed external firm, independent of line management, with an escalation route for matters involving senior people.

IMPLEMENTATION ACTIVITIES

1. Decide who investigates suspected fraud: an internal team, an appointed external firm, or both.
2. Set out their independence from line management and the route for matters involving senior people.
3. Record each matter assigned, and review the arrangement each year.

RECORDS TO KEEP · E61

Investigation mandate
Cycle: each year

SUCCESS MEASURE · M63

In the period, every matter of suspected fraud was assigned to the designated investigators.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

APPENDIX D

Records management should maintain

The records each control should produce as it operates, for management to keep. MK has not requested, received or examined any of them. Independent review of evidence is a separate Advisory service; this report does not perform it.

REF	RECORD AND WHAT IT SHOWS	CONTROLS	KEPT BY
E01	Fraud risk mandate: the authority granted, the budget, who approved them and the date of the last review.	C01	Chief executive
E02	Fraud capability arrangement: who provides the capability, the scope and response times agreed, and the matters referred to it.	C02	Chief executive
E03	Annual fraud risk plan: each piece of work with its owner, date and budget, the approval and each progress report.	C03	Chief financial officer
E04	Fraud training record: each lead's qualifications, development plan and continuing education.	C04	Chief financial officer
E05	Fraud risk register: for each risk, the perpetrator, the method and the process affected.	C05	Fraud risk lead
E06	Process walkthrough notes: for each high-risk process, the steps reviewed, who took part and the fraud opportunities found.	C06	Fraud risk lead
E07	Assessment acceptance record: the meeting that accepted the assessment, each significant risk's owner and their agreement.	C07	Fraud risk lead
E08	Assessment participation record: for each high-risk process, who took part and how.	C08	Fraud risk lead
E09	Fraud risk register: for each relevant process, the AI-enabled schemes considered, the controls they could defeat and the date last reviewed.	C09	Fraud risk lead
E10	Fraud risk register: each AI tool in use, how it could be manipulated or misused and the control that addresses it.	C10	Fraud risk lead
E11	Fraud risk register: for each high-risk process, the AI methods considered and whether existing controls would stop them.	C11	Fraud risk lead
E12	Control assessment: each control that relies on recognition, whether a fake could defeat it and the change made.	C12	Fraud risk lead
E13	Simulation record: the scenario tested, who was targeted, what happened and the actions taken.	C13	Fraud risk lead
E14	Fraud risk register: each risk's likelihood and impact rating, the scale used and the comparison with tolerance.	C14	Fraud risk lead
E15	Fraud risk register: each risk with its rating, controls, decision, owner and the date last reviewed.	C15	Fraud risk lead
E16	Process owner confirmations: each process owner, the risks and controls shared with them and their confirmation or corrections.	C16	Fraud risk lead
E17	Leadership training record: each director and senior manager, the training completed and the date.	C17	HR and payroll lead
E18	Bribery risk assessment: each high-risk activity and the extra controls applied to it.	C18	Legal and compliance lead
E19	Training completion record: each new employee, the training completed and the date.	C19	HR and payroll lead
E20	Code of conduct: the approved text, who approved it, when, and the date of the next review.	C20	HR and payroll lead
E21	Review report: the scope, the findings, management's responses and the status of each finding.	C21, C33, C42	Ethics lead; Internal audit; HR and payroll lead
E22	Ethics trend report: declarations, gifts and breaches by area and over time, and the oversight body's response.	C22	Ethics lead
E23	Donation approval file: the recipient, the checks made, any link found and who approved the payment.	C23	Ethics lead
E24	Supplier approval log: who captured each supplier, who approved it and when.	C24	Procurement lead
E25	Supplier set-up file: the CIPC or other independent search result, the directors and owners identified and the date.	C25	Procurement lead
E26	Supplier and employee match report: the comparison run, each match found and its conclusion.	C26	Procurement lead
E27	Supplier re-check log: each supplier re-checked, the checks repeated, the result and any action taken.	C27	Procurement lead
E28	Dormant supplier report: suppliers unused for the set period, the date each was deactivated and any reactivation with its checks.	C28	Procurement lead

REF	RECORD AND WHAT IT SHOWS	CONTROLS	KEPT BY
E29	Purchase order or approval record: what was approved, by whom, the amount and the date.	C29	Procurement lead
E30	Goods received note: what was received, the quantity, who received it and the date.	C30	Operations lead
E31	Service delivery confirmation: the service, the person who received it, what they confirmed and the date.	C31	Operations lead
E32	Monthly exception review: the patterns checked, the exceptions found, who reviewed them and the conclusion for each.	C32	Internal audit
E33	Split order report: orders grouped by supplier and period, each instance found and its conclusion.	C34	Procurement lead
E34	Monthly payment review: the list reviewed, the reviewer, each query raised and its answer.	C35	Finance lead
E35	Contract register: each contract's supplier, value, term, owner and renewal or end date.	C36	Procurement lead
E36	Variation approval record: each variation above the threshold, its percentage of the original value and the senior approval.	C37	Procurement lead
E37	Contract register: each ongoing or significant supplier, whether a signed contract exists and where it is kept.	C38	Procurement lead
E38	Bank change report review: the report, the reviewer and the confirmation traced for each change.	C39	HR and payroll lead
E39	New starter file: the signed appointment, the payroll record, who captured it, who checked it and when.	C40	HR and payroll lead
E40	Payroll analytics review: the tests run, the exceptions found, the reviewer and each conclusion.	C41	HR and payroll lead
E41	Timesheet approval record: each timesheet, the hours claimed, the supervisor's approval and the date.	C43	HR and payroll lead
E42	List of high-risk roles: each role, why it is high-risk, the people in it and the date last reviewed.	C44	HR and payroll lead
E43	Cover arrangement log: each cover arrangement, the duties covered, the conflict check and the approval.	C45	HR and payroll lead
E44	Concerns log: each concern, who assessed it, the outcome and when.	C46	HR and payroll lead
E45	Support programme record: the support offered, how it was communicated and its use in aggregate.	C47	HR and payroll lead
E46	Banking platform role report: each user, their capture and authorisation rights, approved exceptions and the date of the last review.	C48	Finance lead
E47	Refund record: the original payment method, the account refunded and any approved exception.	C49	Commercial and customer lead
E48	Cash hand-over sheet: each hand-over, the amount counted and both signatures.	C50	Operations lead
E49	Deposit reconciliation: each deposit or collection matched to the bank statement, who prepared it, and each difference with its explanation.	C51	Operations lead
E50	Takings-to-activity reconciliation: the independent record used, the takings compared and each difference with its explanation.	C52	Operations lead
E51	Store access register: the people authorised for each store, and each visitor and contractor with their times of entry and exit.	C53	Operations lead
E52	Issue record: the approved requisition or order, the goods issued and who issued and received them.	C54	Operations lead
E53	Stock system access list: who holds stock, who can change stock records, approved exceptions and the date of the last review.	C55	Operations lead
E54	Secure area register: the items held, the controls applied and each access to the area.	C56	Operations lead
E55	Adjustment record: each difference, its investigation, the explanation and the approval.	C57	Finance lead
E56	Stock record: each stock line, its movements and the quantity expected at any time.	C58	Operations lead
E57	Loss report: losses by type and location over time, and the actions taken.	C59	Finance lead
E58	Alert log: each alert, who reviewed it, when and the outcome.	C60	IT lead
E59	Speak-up log: each report, its assessment, who handled it and the outcome.	C61	Investigations lead
E60	Reporter protection log: each report, the risk assessed, the steps taken and who decided.	C62	Ethics lead
E61	Investigation mandate: who investigates, their independence, the escalation routes and each matter assigned.	C63	Investigations lead

APPENDIX E

Action register

Every action in the programme, grouped by proposed stage. The windows are proposals for planning, not deadlines or estimates.

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
STAGE 1 · ESTABLISH THE FACTS Proposed start: month 1				
A01	Establish which answer is right for the scenario where AI-enabled schemes are not considered: AI-enabled fraud covered and AI methods tested per process.	Fraud risk lead	A corrected answer, or a recorded decision to put the missing practice in place.	The answers for this scenario agree with each other and with how the process runs.
A02	Answer the question the answers leave open for the scenario where risks above tolerance are left without action: without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response?	Fraud risk lead	A written answer, added to the assessment record.	The answer shows either how the reported control operates or that a practice needs to be put in place.
A03	Answer the question the answers leave open for the scenario where invoices are paid for goods or services not received or not agreed: for deliveries where receipt is not recorded before the invoice is paid, what confirmation of receipt does the invoice check rely on, and who gives it?	Finance lead	A written answer, added to the assessment record.	The answer shows either how the reported control operates or that a practice needs to be put in place.
A04	Answer the question the answers leave open for the scenario where an insider in a high-risk role works unchecked: without a maintained list of high-risk roles, how does management confirm that the block leave requirement reaches every sensitive role?	HR and payroll lead	A written answer, added to the assessment record.	The answer shows either how the reported control operates or that a practice needs to be put in place.
A05	Answer the question the answers leave open for the scenario where stock is stolen and hidden in the counts: what is each stock count compared with to identify losses, given that stock is not formally recorded?	Finance lead	A written answer, added to the assessment record.	The answer shows either how the reported control operates or that a practice needs to be put in place.
A06	Answer the question the answers leave open for the scenario where an investigation is not independent or fair: when suspected fraud is investigated, does a line manager ever investigate a matter in the area they manage, and if so, how is independence achieved?	Investigations lead	A written answer, added to the assessment record.	The answer shows either how the reported control operates or that a practice needs to be put in place.
STAGE 2 · DECIDE AND ASSIGN Proposed start: months 1 to 3				
A07	Name the executive accountable for fraud risk assessment, where 1 scenario is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A08	Name the executive accountable for ethics, where 1 scenario is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A09	Name the executive accountable for procurement, where 1 scenario is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A10	Name the executive accountable for people, where 1 scenario is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A11	Name the executive accountable for assets, where 1 scenario is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A12	Decide which of the 4 scenarios with a control reported as a gap to address in this cycle, and in what order, using the decision factors in the finding register.	Chief executive	A recorded selection and order, with the factors that decided each choice.	Every open scenario is either selected, deferred with a reason, or accepted as a risk at the right level.
A13	Approve the target design for each selected control, using the target practice, records and measure in the control blueprint register.	Chief executive	Approved designs, each with an owner and the records it will keep.	Each selected control has an approved design and an owner.
STAGE 3 · PUT THE SELECTED CONTROLS IN PLACE Proposed start: once designs are approved				

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A14	Put in place the control the ethics lead owns: recipients checked for links (C23).	Ethics lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A15	Put in place the 2 controls the finance lead owns: senior review of supplier payments (C35) and losses tracked and reported (C59).	Finance lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A16	Put in place the control the HR and payroll lead owns: hours approved by supervisor (C43).	HR and payroll lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
STAGE 4 · STRENGTHEN FURTHER DEFENCES Proposed start: after the first controls are in place				
A17	Strengthen the 2 controls the chief executive owns: owner has authority across the organisation (C01) and dedicated fraud capability (C02).	Chief executive	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A18	Strengthen the 2 controls the chief financial officer owns: annual fraud action plan (C03) and qualified fraud leads (C04).	Chief financial officer	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A19	Strengthen the 10 controls the fraud risk lead owns: risks described as schemes (C05), processes walked through (C06), management owns the results (C07), process owners take part (C08), own AI tools in scope (C10) and controls tested against AI fakes (C12) and 4 more.	Fraud risk lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A20	Strengthen the 11 controls the HR and payroll lead owns: leaders trained on their duties (C17), training on joining (C19), written code of conduct (C20), bank change report reviewed (C39), new employee checked by another person (C40) and payroll data analysed (C41) and 5 more.	HR and payroll lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A21	Strengthen the control the legal and compliance lead owns: high-risk activities identified (C18).	Legal and compliance lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A22	Strengthen the 3 controls the ethics lead owns: programme independently reviewed (C21), trends reported upward (C22) and retaliation risk assessed (C62).	Ethics lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A23	Strengthen the 10 controls the procurement lead owns: new supplier approved by another person (C24), directors identified (C25), directors compared with staff (C26), suppliers re-checked (C27), dormant suppliers deactivated (C28) and approved order before commitment (C29) and 4 more.	Procurement lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A24	Strengthen the 10 controls the operations lead owns: receipt recorded before payment (C30), services confirmed (C31), dual control at hand-overs (C50), deposits reconciled independently (C51), takings checked against an independent record (C52) and store access limited (C53) and 4 more.	Operations lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A25	Strengthen the 2 controls the internal audit owns: data reviewed for unusual patterns (C32) and independent review of procurement (C33).	Internal audit	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A26	Strengthen the 2 controls the finance lead owns: capture and authorise separated (C48) and differences explained before adjusting (C57).	Finance lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A27	Strengthen the control the commercial and customer lead owns: refunds to the original source (C49).	Commercial and customer lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A28	Strengthen the control the IT lead owns: mailbox rules and odd logins alerted (C60).	IT lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A29	Strengthen the 2 controls the investigations lead owns: speak-up channel (C61) and who investigates (C63).	Investigations lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
STAGE 5 · OPERATE, MEASURE AND REPORT From the first control in operation, through month 12				
A30	Check each of the 2 controls owned by the chief executive against its success measure once it has completed its first full operating cycle.	Chief executive	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A31	Check each of the 2 controls owned by the chief financial officer against its success measure once it has completed its first full operating cycle.	Chief financial officer	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A32	Check each of the 12 controls owned by the fraud risk lead against its success measure once it has completed its first full operating cycle.	Fraud risk lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A33	Check each of the 12 controls owned by the HR and payroll lead against its success measure once it has completed its first full operating cycle.	HR and payroll lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A34	Check the control owned by the legal and compliance lead against its success measure once it has completed its first full operating cycle.	Legal and compliance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A35	Check each of the 4 controls owned by the ethics lead against its success measure once it has completed its first full operating cycle.	Ethics lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A36	Check each of the 10 controls owned by the procurement lead against its success measure once it has completed its first full operating cycle.	Procurement lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A37	Check each of the 10 controls owned by the operations lead against its success measure once it has completed its first full operating cycle.	Operations lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A38	Check each of the 2 controls owned by the internal audit against its success measure once it has completed its first full operating cycle.	Internal audit	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A39	Check each of the 4 controls owned by the finance lead against its success measure once it has completed its first full operating cycle.	Finance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A40	Check the control owned by the commercial and customer lead against its success measure once it has completed its first full operating cycle.	Commercial and customer lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A41	Check the control owned by the IT lead against its success measure once it has completed its first full operating cycle.	IT lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A42	Check each of the 2 controls owned by the investigations lead against its success measure once it has completed its first full operating cycle.	Investigations lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A43	Report the status of every open and unresolved scenario to the board at each of its meetings until each is closed, deferred with a reason or accepted.	Chief executive	A one-page status: scenario, owner, controls in place, controls outstanding, next step.	The status is received and minuted at each meeting.

APPENDIX F

Management scorecard

The success measures, grouped by the owner who reports them, with each control's operating cycle. Each measure is stated once, in full, in its control's blueprint (Appendix C) and in the supporting workbook.

MEASURE	CONTROL	CONTROL NAME	OPERATING CYCLE
CHIEF EXECUTIVE 2 measures			
M01	C01	Owner has authority across the organisation	each year
M02	C02	Dedicated fraud capability	each year
CHIEF FINANCIAL OFFICER 2 measures			
M03	C03	Annual fraud action plan	each year
M04	C04	Qualified fraud leads	each year
COMMERCIAL AND CUSTOMER LEAD 1 measure			
M49	C49	Refunds to the original source	before each refund is paid
ETHICS LEAD 4 measures			
M21	C21	Programme independently reviewed	within the last three years
M22	C22	Trends reported upward	at least twice a year
M23	C23	Recipients checked for links	before each commitment
M62	C62	Retaliation risk assessed	each year
FINANCE LEAD 4 measures			
M35	C35	Senior review of supplier payments	monthly
M48	C48	Capture and authorise separated	each quarter
M57	C57	Differences explained before adjusting	after each count
M59	C59	Losses tracked and reported	monthly
FRAUD RISK LEAD 12 measures			
M05	C05	Risks described as schemes	at each assessment and update
M06	C06	Processes walked through	at each assessment
M07	C07	Management owns the results	after each assessment
M08	C08	Process owners take part	at each assessment
M09	C09	AI-enabled fraud covered	at each assessment and update
M10	C10	Own AI tools in scope	at each assessment and update
M11	C11	AI methods tested per process	at each assessment and update
M12	C12	Controls tested against AI fakes	at each assessment and update
M13	C13	Simulated AI attack	at least once a year
M14	C14	Likelihood and impact rated	at each assessment and update
M15	C15	Assessment documented	at each assessment and update
M16	C16	Owners know their risks	after each assessment
HR AND PAYROLL LEAD 12 measures			
M17	C17	Leaders trained on their duties	each year
M19	C19	Training on joining	monthly
M20	C20	Written code of conduct	every two years

MEASURE	CONTROL	CONTROL NAME	OPERATING CYCLE
M39	C39	Bank change report reviewed	before each pay run
M40	C40	New employee checked by another person	before each first pay run
M41	C41	Payroll data analysed	each pay run
M42	C42	Independent review of payroll	within the last two years
M43	C43	Hours approved by supervisor	each pay run
M44	C44	High-risk roles identified	each year
M45	C45	No conflicting duties when covering	whenever cover is arranged
M46	C46	Concerns raised fairly	each year
M47	C47	Support for financial pressure	each year
INTERNAL AUDIT 2 measures			
M32	C32	Data reviewed for unusual patterns	monthly
M33	C33	Independent review of procurement	within the last two years
INVESTIGATIONS LEAD 2 measures			
M61	C61	Speak-up channel	each year
M63	C63	Who investigates	each year
IT LEAD 1 measure			
M60	C60	Mailbox rules and odd logins alerted	daily
LEGAL AND COMPLIANCE LEAD 1 measure			
M18	C18	High-risk activities identified	at each assessment and update
OPERATIONS LEAD 10 measures			
M30	C30	Receipt recorded before payment	before each payment
M31	C31	Services confirmed	before each payment
M50	C50	Dual control at hand-overs	at each hand-over
M51	C51	Deposits reconciled independently	daily
M52	C52	Takings checked against an independent record	daily
M53	C53	Store access limited	monthly
M54	C54	Issues against approved requests	before goods leave the store
M55	C55	Custody separated from records	each quarter
M56	C56	High-value items secured	monthly
M58	C58	How stock is recorded	at each count
PROCUREMENT LEAD 10 measures			
M24	C24	New supplier approved by another person	before each new supplier becomes active
M25	C25	Directors identified	before each new supplier is first paid
M26	C26	Directors compared with staff	at set-up and at least once a year
M27	C27	Suppliers re-checked	each year
M28	C28	Dormant suppliers deactivated	each quarter
M29	C29	Approved order before commitment	before each commitment
M34	C34	Split orders monitored	monthly
M36	C36	Contract register	each quarter
M37	C37	Large variations escalated	before each large variation proceeds
M38	C38	Written supplier contracts	each quarter

APPENDIX G

Answer relationships

For each control reported fully in place, every related practice of the same scenario reported weaker, with no case yet or outstanding, and how the two relate. A practice answered "not applicable" is outside scope and is not listed. Only answers that cannot both be right, or a control lacking an input it needs, are unresolved inconsistencies; a reviewed pair the answers leave open is a question to clarify; a pair not yet reviewed supports no conclusion.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S01	**Executive accountable for fraud**	Owner has authority across the organisation: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Executive accountable for fraud asks whether accountability for fraud risk is formally assigned; Owner has authority across the organisation asks whether that person has the authority and budget to act across the organisation. Accountability can be assigned without that authority, so neither answer makes the other untrue. The scheme's own description names both ownership and authority to act, so the scheme is only partly addressed.
S01	**Executive accountable for fraud**	Dedicated fraud capability: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	A dedicated fraud function or provider is a separate resource; formal accountability does not require one.
S01	**Executive accountable for fraud**	Annual fraud action plan: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	An annual plan or budget for fraud work is a separate practice from assigning accountability.
S01	**Executive accountable for fraud**	Qualified fraud leads: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	The qualifications of the people leading fraud work are a separate question; the method asks it wherever someone handles fraud risk.
S13	**Fraud risks assessed**	Management has not seen or accepted the results.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Whether management formally accepts the results is asked separately from whether an assessment was done; an assessment can be done without formal acceptance.
S13	**Fraud risks assessed**	Process owners take part: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Participation of process owners is a quality of the assessment, not a condition of having done one.
S13	**Fraud risks assessed**	Some risks describe a scheme, but most remain general.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Describing risks as specific schemes is a quality of the assessment. The candidate-confirmation review found it distinct but route-conditional; it is not a condition of Fraud risks assessed.
S13	**Fraud risks assessed**	Processes walked through: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Walking through each high-risk process is a quality of the assessment, not a condition of having done one.
S14	**AI-enabled fraud covered**	Controls tested against AI fakes: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Assessing whether verification controls could be defeated by an AI-generated fake is a control-evaluation step, distinct from identifying AI-enabled schemes in the risk assessment.
S14	**AI-enabled fraud covered**	Own AI tools in scope: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Misuse of the organisation's own AI tools is a different exposure from AI-enabled fraud aimed at the organisation.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S14	**AI-enabled fraud covered**	AI methods tested per process: reported as not in place.	**ANSWERS THAT CANNOT BOTH BE RIGHT** Reviewed pair	The answers about AI-enabled fraud cannot both be right as given: one says AI-enabled schemes are assessed for every relevant process, the other that, for high-risk processes, the assessment does not ask how AI could be used against them.
S14	**AI-enabled fraud covered**	Simulated AI attack: partly in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	A simulated AI attack tests controls; it is not a condition of considering AI-enabled schemes.
S17	**Response decided**	Likelihood and impact rated: reported as not in place.	**QUESTION TO CLARIFY** Reviewed pair	A response is reported as decided for every risk above tolerance, while rating each risk for likelihood and harm is reported as not in place. Risks above tolerance can be identified without ratings, but the answers do not say how this is done. **Question:** Without likelihood and harm ratings, how does management identify which fraud risks are above tolerance and need a decided response?
S18	**Updated when the business changes**	Assessment documented: reported in place only in some areas, cases or periods.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	The assessment is reported as partly documented; updating on change can operate on a partly documented assessment.
S18	**Updated when the business changes**	Owners know their risks: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Whether process owners know the risks recorded for their area is a separate practice from updating the assessment when the business changes.
S19	**Bribery prohibited**	The main high-risk activities are identified, and some have extra controls.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Identifying high-risk activities directs extra controls; the prohibition does not depend on it.
S19	**Bribery prohibited**	Leaders trained on their duties: reported as set out or agreed but not yet working in practice.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Training directors and senior managers on their personal duties is separate from the prohibition itself.
S25	**Code accessible to staff**	Written code of conduct: not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Code accessible to staff asks about standards of conduct 'whether in a written code or not', so it does not depend on a written code.
S25	**Code accessible to staff**	Training on joining: reported as set out or agreed but not yet working in practice.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Fraud and ethics training at joining is distinct from explaining conduct standards where employees work; induction is only one of the places Code accessible to staff names.
S25	**Code accessible to staff**	Programme independently reviewed: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Independent review of the ethics programme is a separate practice.
S25	**Code accessible to staff**	Trends reported upward: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Reporting ethics trends upward is a separate practice.
S29	**New supplier process**	New supplier approved by another person: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	New supplier process at level 4 says every new supplier goes through set checks and an approval before it can be paid; it does not say the approver is someone other than the person who captured the supplier. New supplier approved by another person says they are not separated. The approval exists as reported but is not independent, which weakens the defence against an insider without contradicting the answer.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S29	**New supplier process**	Owners are identified only when something raises a concern.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Identifying directors and owners is one of the checks a process may include; level 4 of New supplier process does not specify it.
S29	**New supplier process**	Directors compared with staff: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Comparing supplier details with employee records is a further check the process may include; level 4 of New supplier process does not specify it.
S29	**New supplier process**	Suppliers re-checked: reported as set out or agreed but not yet working in practice.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Periodic re-checking of existing suppliers is a separate control on the existing supplier file.
S29	**New supplier process**	Dormant suppliers deactivated: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Deactivating dormant suppliers is a separate control on the existing supplier file.
S33	**Three-way match**	Most purchases are approved before commitment, through a purchase order or another record.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	An approval recorded after commitment still lets an invoice be matched to an approved order; approval before commitment is a separate requirement, as the candidate-confirmation review found.
S33	**Three-way match**	Receipt is recorded for most deliveries, but not always before payment.	**QUESTION TO CLARIFY** Reviewed pair	Every invoice is reported as checked against an approved order and a confirmation of receipt before payment, while recording receipt of goods before payment is reported as partly in place. The check may rely on another confirmation where receipt is not recorded; the answers do not say which. **Question:** For deliveries where receipt is not recorded before the invoice is paid, what confirmation of receipt does the invoice check rely on, and who gives it?
S33	**Three-way match**	Services confirmed: reported as not in place.	**QUESTION TO CLARIFY** Reviewed pair	Every invoice, including for services, is reported as checked against a confirmation of receipt before payment, while confirmation of delivery by the person who received the service is reported as not in place. Someone else may confirm delivery; the answers do not say who. **Question:** For service invoices, who confirms that the service was delivered before payment, and is that confirmation recorded?
S41	**Variations approved first**	Written supplier contracts: reported in place only in some areas, cases or periods.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Variations approved first applies 'whether or not there is a written contract', so it does not depend on written contracts.
S41	**Variations approved first**	Contract register: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	A register of active contracts is a separate control.
S41	**Variations approved first**	Large variations escalated: reported as set out or agreed but not yet working in practice.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Escalating large variations adds an approval tier to the approval Variations approved first reports.
S42	**Bank changes confirmed with employee**	Bank change report reviewed: reported in place only in some areas, cases or periods.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Reviewing the bank-change report before each pay run is a detective layer behind confirming each change; confirmation does not depend on it.
S43	**Payroll reviewed by another person**	The person who captures the record checks it themselves.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Checking each new record against a signed appointment is a separate control at set-up; the pay-run review does not depend on it.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S43	**Payroll reviewed by another person**	Payroll data analysed: reported as set out or agreed but not yet working in practice.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Analysing payroll data is a separate detective practice.
S43	**Payroll reviewed by another person**	Independent review of payroll: partly in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	An internal audit or external review of payroll is a separate assurance practice.
S52	**Block leave required**	Managers know informally which roles are risky.	QUESTION TO CLARIFY Reviewed pair	Block leave is reported for everyone in a sensitive role, while identifying high-risk roles on a maintained list is reported as partly in place. The requirement can reach every sensitive role without a list, but the answers do not show how management knows that it does. **Question:** Without a maintained list of high-risk roles, how does management confirm that the block leave requirement reaches every sensitive role?
S52	**Block leave required**	No conflicting duties when covering: reported as set out or agreed but not yet working in practice.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Keeping cover staff from conflicting duties strengthens block leave; leave can be taken without it.
S52	**Block leave required**	Concerns raised fairly: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	A route for managers to raise concerns is a separate practice.
S52	**Block leave required**	Support for financial pressure: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Support for employees in financial difficulty is a separate practice.
S53	**Two authorisers for every payment**	Users can capture payments, load beneficiaries and authorise.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Two authorisers enforced by the bank still require a second person even where the capturer can also authorise; separating capture from authorisation is a further control, not a condition of dual authorisation.
S65	**Refunds approved independently**	Refunds are paid wherever the customer asks.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Independent approval of refunds and paying refunds only to the original source are separate controls on different steps.
S75	**Daily reconciliation**	Cash is counted at some handovers, such as at the end of the day, but not at shift changes.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Dual control when cash changes hands is a separate control from daily reconciliation.
S75	**Daily reconciliation**	Takings checked against an independent record: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Reconciling takings to sales records can operate whether or not those records are independent of the cashier; an independent record strengthens it.
S75	**Daily reconciliation**	Deposits are checked against the statement occasionally.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Reconciling deposits to the bank statement is a separate control at the banking step.
S76	**Independent blind counts**	How stock is recorded: it is not formally recorded.	QUESTION TO CLARIFY Reviewed pair	Counts are reported as independent and blind to recorded quantities, while stock is reported as not formally recorded. A count reveals a loss only when it is compared with an expected quantity; the answers do not say what the counts are compared with. **Question:** What is each stock count compared with to identify losses, given that stock is not formally recorded?
S76	**Independent blind counts**	Store access limited: reported as not in place.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Restricting access to stores is a separate preventive control.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S76	**Independent blind counts**	Issues against approved requests: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Issuing stock against approved requests is a separate preventive control.
S76	**Independent blind counts**	Duties are separated on paper, but storekeepers can still change the records.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Separating custody from records is a separate control; independent counts can operate without it.
S76	**Independent blind counts**	High-value items secured: reported as set out or agreed but not yet working in practice.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Securing high-value items is a separate preventive control.
S76	**Independent blind counts**	Differences explained before adjusting: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Investigating count differences before adjusting records is the step that acts on what counts find; the method asks it separately and does not make the count depend on it.
S85	**Multi-factor on all email**	Mailbox rules and odd logins alerted: reported as not in place.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Alerts on new mailbox rules and unusual logins detect a takeover that gets past multi-factor authentication; they are a further layer, not a condition of it.
S99	**People know whom to tell**	Speak-up channel: only informally, such as telling a manager.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Knowing whom to tell, including someone outside the reporting line, does not require a formal channel; an informal route can meet it.
S100	**Identities kept confidential**	Retaliation risk assessed: reported in place only in some areas, cases or periods.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Assessing each reporter's risk of retaliation is a separate practice from keeping identities confidential.
S100	**Retaliation prohibited and punished**	Retaliation risk assessed: reported in place only in some areas, cases or periods.	**FURTHER DEFENCE WEAKER; CONTROL STANDS** Reviewed pair	Assessing each reporter's risk of retaliation is a separate practice from prohibiting retaliation.
S102	**Investigators independent**	Who investigates: line management or HR.	**QUESTION TO CLARIFY** Reviewed pair	Investigations are reported as always independent of the area concerned, and suspected fraud as investigated by line management or HR. Both can be right if HR or a manager from another area investigates; the answers do not say whether line managers ever investigate their own area. **Question:** When suspected fraud is investigated, does a line manager ever investigate a matter in the area they manage, and if so, how is independence achieved?

APPENDIX H

Outstanding information

Every question asked and not answered. A declined question, a question answered "I don't know" and a question still waiting are all outstanding; none is treated as answered.

No answer is outstanding.

APPENDIX I

Roles used in this report

Each consolidated role and the method's own suggested owners behind it.

ROLE IN THIS REPORT	METHOD WORDING
Chief executive	CEO or company secretary
Chief financial officer	CFO or head of risk
Commercial and customer lead	Customer service or finance manager
Ethics lead	CSI or sustainability lead; Ethics officer or HR manager; Ethics officer or internal audit
Finance lead	Creditors manager or financial controller; Financial controller; Financial controller or internal audit; Financial controller or treasury manager
Fraud risk lead	Head of risk or the CFO; Risk manager or fraud risk lead; Risk manager, with internal audit
HR and payroll lead	HR lead or ethics officer; HR manager; HR manager, with the head of IT; HR or learning lead; HR or payroll manager; Payroll manager; Payroll manager or internal audit
Internal audit	Internal audit or financial controller
Investigations lead	Head of forensics, risk or compliance
IT lead	Head of IT or IT provider
Legal and compliance lead	Compliance or legal lead
Operations lead	Operations or financial manager; Store, branch or cash office manager; Stores or operations manager; Warehouse or stores manager
Procurement lead	Contract manager; Head of procurement or CFO; Procurement manager; Procurement or creditors manager

APPENDIX J

Information coverage

What the assessment establishes and what remains unknown: the confirmations answered in each area and the diagnostic questions put to each function. Questions the method did not ask are not counted, and nothing is concluded about them.

AREA	CONFIRMATIONS THAT APPLY	ANSWERED	SHARE ANSWERED
Fraud governance and accountability	12	12	100%
Fraud risk assessment	6	6	100%
Ethics, integrity and anti-corruption	10	10	100%
Third parties and supply chain	14	14	100%
People, payroll and insider risk	11	11	100%
Finance, banking and financial reporting	12	12	100%
Customers, revenue and products	10	10	100%
Assets, cash and inventory	10	10	100%
Digital, cyber-enabled and identity fraud	14	14	100%
Detection, speak-up and response	9	9	100%

Diagnostic questions put to functions

FUNCTION	ASKED	ANSWERED	DECLINED	NOT KNOWN	WAITING
Operations and sales	11	11	0	0	0
HR and payroll	15	15	0	0	0
Risk and investigations	15	15	0	0	0
Procurement	15	15	0	0	0
Legal, compliance and ethics	3	3	0	0	0
Executive and governance	1	1	0	0	0
Finance	5	5	0	0	0